CESAE Digital
CyberSecurity nas Empresas

Simulação de Ataque, Defesa e Monitorização

RELATÓRIO TÉCNICO

Infraestrutura de Rede

CodeSecure, Lda.

Equipa: Denni Pinho | Antonio Barbosa | João Pinho | Rodrigo Ferrero

Índice

1. Introdução
2. Infraestrutura de Rede
  2.1 Topologia da Rede
  2.2 Endereçamento IP e Segmentação por VLANs
  2.3 Equipamentos de Rede
  2.4 Redundância (HSRP, Spanning-Tree e EtherChannel)
  2.5 Serviços de Rede (DHCP, DNS, HTTP, Email)
  2.6 NAT/PAT e Acesso à Internet
  2.7 VPN de Acesso Remoto (IPSec)
    2.7.1 Justificação Técnica
    2.7.2 Arquitetura da Solução
    2.7.3 Configuração Implementada
    2.7.4 Testes de Funcionamento
3. Segurança da Infraestrutura de Rede
  3.1 ACLs e Políticas de Firewall
  3.2 Fortalecimento da Segurança dos Equipamentos
  3.3 Port Security
  3.4 Centralização de Logs (Syslog)
4. Servidores Data Center
  4.1 Diagrama Arquitetura
  4.2 Servidor de Partilha de Ficheiros (Ubuntu Server + Samba)
    4.2.1 Criação e Configuração da Máquina Virtual
    4.2.2 Configuração de Rede
    4.2.3 Instalação e Configuração do Samba
    4.2.4 Grupos, Utilizadores e Permissões
    4.2.5 Testes de Acesso às Partilhas
    4.2.6 Hardening do Servidor
  4.3 Wazuh Server
  4.4 Windows Server
5. Máquinas Clientes DMZ
  5.1 Introdução
  5.2 Configuração do Servidor de Alojamento Web
    5.2.1 Instalação do Podman
    5.2.2 Estrutura de Ficheiros dos Clientes
    5.2.3 Configuração dos Containers
  5.3 RedHat

5.4 Testes de Funcionamento
5.4.1 Verificação dos Estado dos Containers
5.4.2 Acesso Externo via Browser
5.5 Auto arranque dos Containers
6. Máquina Vulnerável
6.1 Introdução
6.2 Enumeração de portas e serviços
6.2.1 Scan com a ferramenta nmap
6.2.2 Scan com a ferramenta Nessus
6.3 Vulnerabilidades Identificadas
6.3.1 Sistema Operativo
6.3.2 Serviço SSH (Porta 22)
6.3.3 Serviço HTTP (Porta 80)
6.4 Testes de Penetração
6.4.1 Exploração do serviço SSH
6.4.2 Exploração do serviço HTTP
6.5 Análise Global de Risco
6.6 Proposta de Novo Servidor Seguro
6.6.1 Serviços configurados no novo servidor
6.6.2 Configurações adicionais
6.7 Síntese dos Resultados
7. Conclusão
8. Referências Bibliográficas

1. Introdução

O presente relatório documenta o trabalho desenvolvido no âmbito do projeto final integrador do curso de Network & CyberSecurity Administrator, promovido pelo CESAE Digital. O projeto teve como objetivo a concepção, implementação e análise de uma infraestrutura informática segura para a empresa fictícia CodeSecure, Lda., integrando componentes de redes, administração de sistemas e cibersegurança.
A CodeSecure, Lda. é uma empresa de média dimensão, com cerca de 40 funcionários, dedicada ao desenvolvimento de software e ao alojamento de websites e serviços digitais para clientes externos. A empresa possui atualmente 120 sites alojados e 14 máquinas virtuais de empresas externas no seu datacenter próprio. A organização está estruturada em três departamentos principais: Recursos Humanos, Programação e Suporte Técnico.
O projeto foi desenvolvido em equipa, composta por quatro elementos, sendo que o presente relatório incide sobre as componentes atribuídas ao autor: a concepção e implementação da infraestrutura de rede em Cisco Packet Tracer e a configuração de um servidor de partilha de ficheiros baseado em Ubuntu Server com Samba.
A distribuição de tarefas pela equipa foi realizada da seguinte forma:

Membro	Responsabilidade
Denni Pinho	Packet Tracer (infraestrutura de rede) + Ubuntu Server com Samba
Antonio Barbosa	Windows Server 2019 (Active Directory/DNS/DHCP) + Wazuh Server (SIEM)
João Pinho	Podman + RedHat VM (Containers de clientes)
Rodrigo Ferrero	VM Vulnerável (Pentest) + Wazuh Agents

Tabela 1 — Distribuição de tarefas pela equipa.

2. Infraestrutura de Rede

A infraestrutura de rede foi concebida e implementada em Cisco Packet Tracer, tendo como base os requisitos do cenário da CodeSecure, Lda. Foi adotada uma abordagem de defesa em profundidade, privilegiando a segmentação de rede por Virtual Local Area Network (VLAN)s, a redundância em equipamentos críticos e a implementação de políticas de controlo de acesso.

2.1 Topologia da Rede

A topologia implementada segue um modelo hierárquico de três camadas, adaptado à dimensão da empresa. Na camada de acesso encontram-se os switches dedicados a cada departamento e zona (SW-RH, SW-Prog, SW-Suporte, Switch-DMZ, Switch0 e Switch1). Na camada de distribuição/core foram utilizados dois switches Layer 3 (Core-SW1 e Core-SW2) que asseguram o inter-VLAN routing e a redundância através do protocolo Hot Standby Router Protocol (HSRP). Na camada de fronteira, um router configurado como firewall principal faz a separação entre a rede interna e a Internet, implementando Network Address Translation (NAT), Port Address Translation (PAT) e Access Control Lists (ACL)s de filtragem.
A simulação da ligação à Internet foi realizada através de um router Internet Servide Provider (ISP) com o endereço público simulado 200.200.200.1/30.

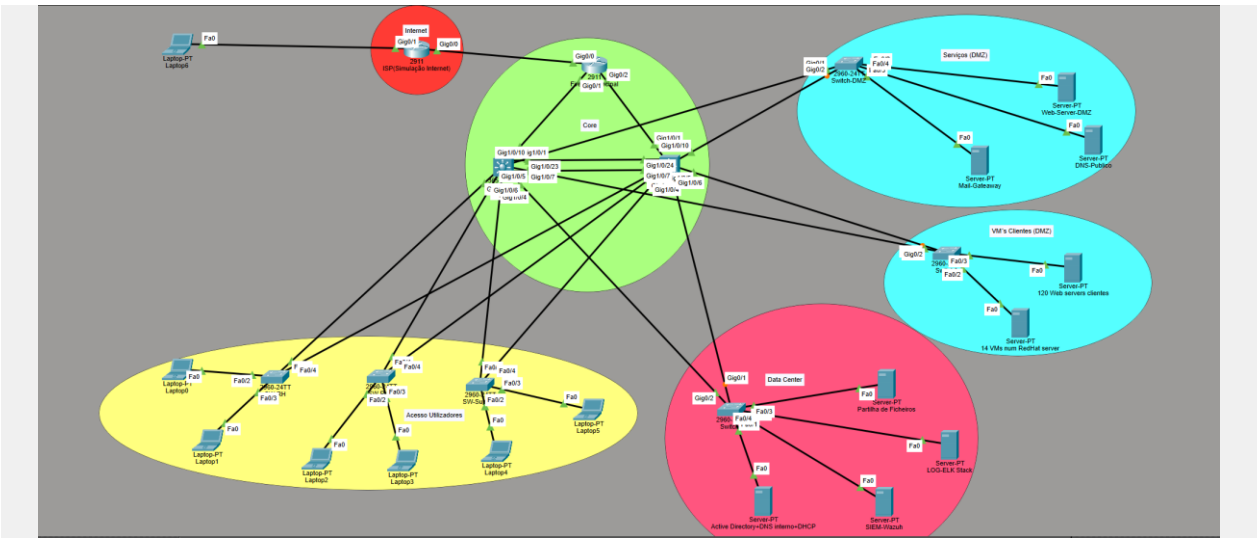


Figura 1 — Topologia completa da rede no Cisco Packet Tracer.

A topologia apresentada na Figura 1 ilustra a separação clara entre as diferentes zonas da rede: a zona interna (departamentos), o datacenter, a Zona Demilitarizada (DMZ) de serviços, a DMZ de clientes e a ligação à Internet. Esta separação é fundamental para limitar o impacto de eventuais compromissos de segurança.

2.2 Endereçamento IP e Segmentação por VLANs

Foi definido um esquema de endereçamento Internet Protocol (IP) estruturado, utilizando a gama privada 192.168.x.0/24 para as redes internas e uma gama pública simulada (200.200.200.0/30) para a ligação ao ISP. Cada departamento e zona da empresa foi isolado numa VLAN distinta, garantindo a segmentação de tráfego e o controlo granular de acessos.
A decisão de utilizar sub-redes /24 para cada VLAN justifica-se pela simplicidade de gestão e pela capacidade adequada ao número de hosts previstos em cada segmento.
A tabela seguinte apresenta o esquema de segmentação implementado:

VLAN	Nome	Sub-rede	Gateway	Descrição
10	**RH**	192.168.10.0/24	192.168.10.1	Recursos Humanos
20	**Programação**	192.168.20.0/24	192.168.20.1	Dept. Programação
30	**Suporte**	192.168.30.0/24	192.168.30.1	Suporte Técnico
40	**DataCenter**	192.168.40.0/24	192.168.40.1	Servidores internos
50	**DMZ-Serviços**	192.168.50.0/24	192.168.50.1	Serviços expostos
60	**DMZ-Clientes**	192.168.60.0/24	192.168.60.1	Alojamento clientes
99	**Gestão**	192.168.99.0/24	192.168.99.1	Management

Tabela 2 — Esquema de segmentação por VLANs.

A VLAN 99 foi definida como VLAN de gestão e configurada como native VLAN em todos os trunks, substituindo a VLAN 1 por defeito. Esta é uma prática recomendada de segurança, uma vez que a VLAN 1 é frequentemente alvo de ataques como VLAN hopping.

2.3 Equipamentos de Rede

A infraestrutura de rede foi implementada com os seguintes equipamentos no Packet Tracer:

Equipamento	Modelo	Função
ISP	Router 2911	Simulação da ligação Internet
Firewall Principal	Router 2911	Firewall, NAT/PAT, ACLs, fronteira de rede

Core-SW1	Switch 3560	Core switch primário, HSRP Active, Root Primary
Core-SW2	Switch 3560	Core switch secundário, HSRP Standby, Root Secondary
SW-RH	Switch 2960	Acesso departamento RH (VLAN 10)
SW-Prog	Switch 2960	Acesso departamento Programação (VLAN 20)
SW-Suporte	Switch 2960	Acesso departamento Suporte (VLAN 30)
Switch-DMZ	Switch 2960	Zona DMZ de serviços (VLAN 50)
Switch0	Switch 2960	VMs de clientes (VLAN 60)
Switch1	Switch 2960	Data Center (VLAN 40)

Tabela 3 — Equipamentos de rede utilizados na infraestrutura.

A escolha de switches Layer 3 (modelo 3560) para o core da rede permitiu a realização de inter-VLAN routing sem necessidade de recorrer ao router principal, melhorando a performance e reduzindo a latência. Os switches de acesso (modelo 2960) foram utilizados nas camadas de distribuição departamental, proporcionando funcionalidades adequadas como port security e spanning-tree portfast.

2.4 Redundância (HSRP, Spanning-Tree e EtherChannel)

A redundância foi um dos requisitos fundamentais do projeto. Foram implementados múltiplos mecanismos para garantir a continuidade do serviço em caso de falha:
No que diz respeito à redundância de gateway, foi configurado o protocolo HSRP (Hot Standby Router Protocol) em todas as Switch Virtual Interfaces (SVI)s dos Core Switches. O Core-SW1 foi definido como router ativo (priority 110) e o Core-SW2 como standby (priority 100), com preempt ativado.
Desta forma, o gateway virtual (ex: 192.168.10.1) é partilhado entre ambos os switches, assegurando failover automático caso o switch primário fique indisponível.
Relativamente à redundância de caminhos, todos os switches de acesso possuem ligações trunk duplas, uma para o Core-SW1 (primária) e outra para o Core-SW2 (secundária). O Spanning-Tree Protocol (STP) foi configurado com o Core-SW1 como root primary e o Core-SW2 como root secondary para todas as VLANs, garantindo a prevenção de loops e uma convergência rápida em caso de falha.
Adicionalmente, o Firewall Principal possui duas ligações ponto-a-ponto, uma para cada Core Switch, com rotas estáticas de backup configuradas através de métricas diferenciadas.

```
Core-SW1#show standby brief
                     P indicates configured to preempt.
                     |
Interface   Grp  Pri P State    Active          Standby         Virtual IP
Vl10        10   110 P Active   local           192.168.10.3    192.168.10.1
Vl20        20   110 P Active   local           192.168.20.3    192.168.20.1
Vl30        30   110 P Active   local           192.168.30.3    192.168.30.1
Vl40        40   110 P Active   local           192.168.40.3    192.168.40.1
Vl50        50   110 P Active   local           192.168.50.3    192.168.50.1
Vl60        60   110 P Active   local           192.168.60.3    192.168.60.1
Vl99        99   110 P Active   local           192.168.99.3    192.168.99.1
Core-SW1#
```

Figura 2 — Verificação do HSRP no Core-SW1 (*show standby brief*).

Conforme observado na Figura 2, o Core-SW1 encontra-se no estado Active para todas as VLANs, confirmando o correto funcionamento do HSRP e a disponibilidade do gateway virtual para os utilizadores.
No que diz respeito à agregação de ligações, foi implementado um EtherChannel entre o Core-SW1 e o Core-SW2, agregando duas interfaces físicas (GigabitEthernet1/0/5 e GigabitEthernet1/0/7) num único canal lógico (Port-channel 1). Esta configuração duplica a largura de banda disponível entre os dois core switches para 2 Gbps e proporciona failover instantâneo caso uma das ligações físicas falhe. O EtherChannel foi configurado em modo estático (mode on), com trunk nativo na VLAN 99 e transporte de todas as VLANs operacionais (10, 20, 30, 40, 50, 60 e 99).

```
Group  Port-channel  Protocol    Ports
------+-------------+-----------+-----------------------------------------------

1      Po1(SU)           LACP   Gig1/0/7(P)
Core-SW1#
```

Figura 3 — Verificação do EtherChannel entre Core-SW1 e Core-SW2 (*show etherchannel summary).*

A combinação de HSRP, Spanning-Tree e EtherChannel assegura uma infraestrutura resiliente com múltiplos níveis de redundância, minimizando o risco de indisponibilidade por falha de equipamento ou ligação.

2.5 Serviços de Rede (DHCP, DNS, HTTP, Email)

Foram configurados diversos serviços de rede essenciais ao funcionamento da empresa, de forma a simular um ambiente de produção realista.
O serviço Dynamic Host Configuration Protocol (DHCP) foi configurado no servidor AD-DC01 (192.168.40.10), com três pools distintas para os departamentos: VLAN 10 (RH), VLAN 20 (Programação) e VLAN 30 (Suporte). O reencaminhamento dos pedidos DHCP foi garantido através de ip helper-address configurado nas SVIs dos Core

Switches, permitindo que os clientes de cada VLAN obtenham endereçamento automático a partir do servidor central.

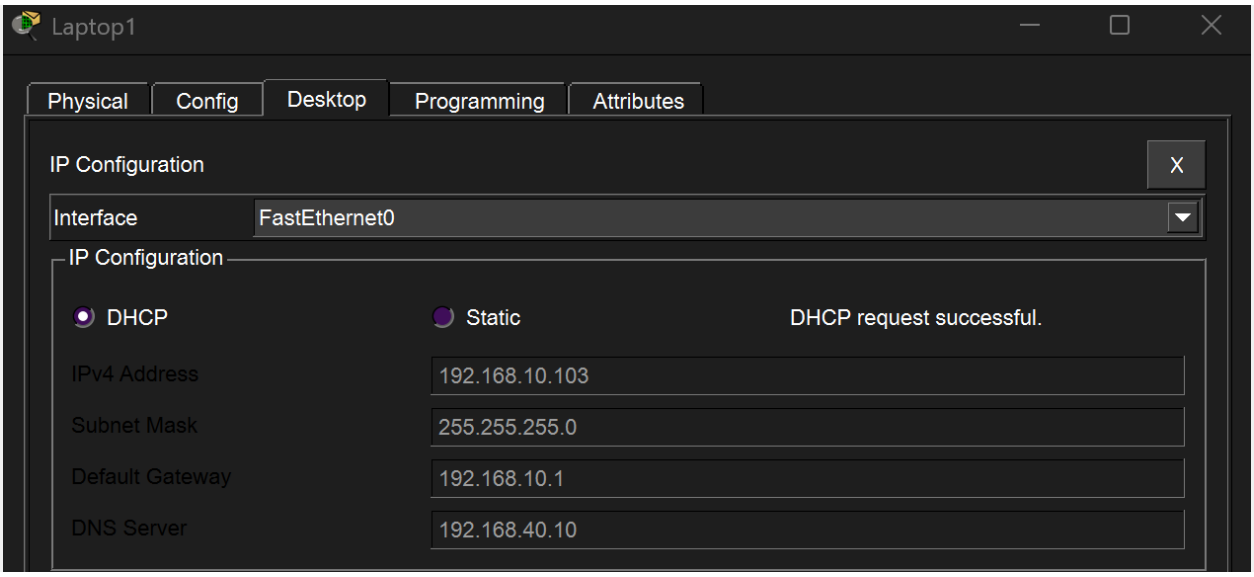


Figura 4 — Laptop a receber IP via DHCP com *gateway* e DNS corretos.

A Figura 4 demonstra que o serviço DHCP está operacional, com o laptop a receber um endereço IP dentro da gama esperada, juntamente com o gateway e Domain Name Systems (DNS) corretos.
O serviço DNS foi implementado em dois níveis: um DNS público (192.168.50.11) com registos para os domínios expostos à Internet (codesecure.pt, www.codesecure.pt, mail.codesecure.pt) e um DNS interno no AD-DC01 (192.168.40.10) com registos para os servidores internos (codesecure.local). Esta separação permite resolver nomes tanto internamente como externamente de forma independente.
O serviço HyperText Transfer Protocol (HTTP) foi ativado no Web-Server-DMZ (192.168.50.10) e no servidor de alojamento de clientes (192.168.60.10), simulando a presença web da empresa e dos clientes alojados. O serviço de email foi configurado no Mail-Gateway (192.168.50.12) com Simple Mail Transfer Protocol (SMTP) e Post Office Protocol Version 3 (POP3) ativos, utilizando o domínio codesecure.pt.

Figura 5 — Acesso ao website da CodeSecure através do browser de um laptop interno (www.codesecure.pt).

A Figura 5 confirma que a resolução DNS e o serviço web estão a funcionar corretamente, permitindo o acesso ao website da empresa a partir da rede interna.

2.6 NAT/PAT e Acesso à Internet

A tradução de endereços foi implementada no Firewall Principal com dois mecanismos distintos. O NAT estático foi configurado para os servidores da DMZ que necessitam de ser acessíveis a partir da Internet, mapeando endereços privados para endereços públicos simulados. O PAT foi configurado para os departamentos internos, permitindo que múltiplos utilizadores acedam à Internet através de um único endereço público.

Servidor	IP Privado	IP Público (NAT)
Web-Server-DMZ	192.168.50.10	200.200.200.10
DNS-Público	192.168.50.11	200.200.200.11
Mail-Gateway	192.168.50.12	200.200.200.12
Web Servers Clientes	192.168.60.10	200.200.200.20
VMs RedHat	192.168.60.11	200.200.200.21

Tabela 4 — Mapeamento NAT estático para servidores expostos.

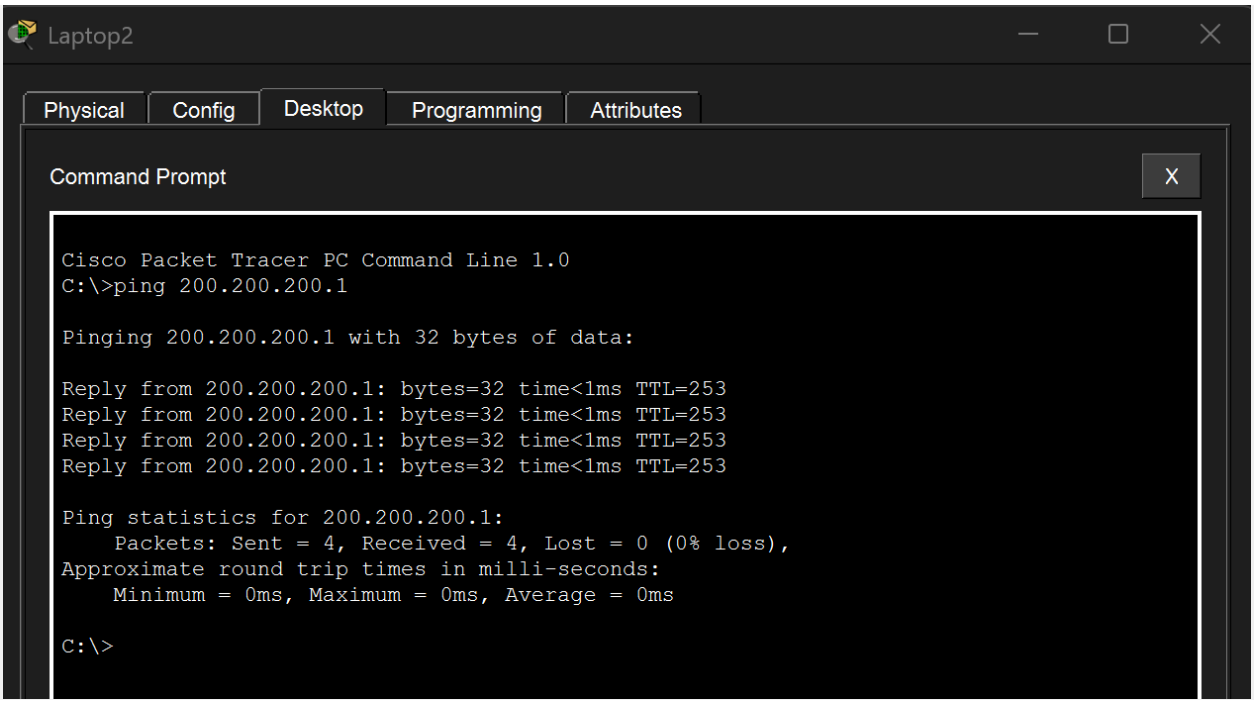


Figura 6 — Teste de conectividade de um laptop interno para a Internet (ping 200.200.200.1).

A Figura 6 comprova que o PAT está a funcionar corretamente, permitindo que os dispositivos internos acedam à Internet através do Firewall Principal.

2.7 VPN de Acesso Remoto (IPSec)

Como funcionalidade adicional ao projeto, foi implementada uma solução de VPN de acesso remoto baseada no protocolo IPSec, permitindo que os elementos do departamento de Programação possam trabalhar remotamente com acesso seguro à infraestrutura interna da CodeSecure. Esta funcionalidade responde a uma necessidade cada vez mais presente nas empresas, especialmente em contextos de trabalho híbrido ou remoto.

2.7.1 Justificação Técnica

A decisão de implementar uma VPN de acesso remoto foi motivada pela necessidade de garantir que a equipa de Programação possa aceder de forma segura aos recursos internos da empresa (Data Center, DMZ e servidores de desenvolvimento) a partir de qualquer localização. O protocolo IPSec foi escolhido por oferecer encriptação forte (AES-256), autenticação robusta e ser nativamente suportado pelo Cisco Packet Tracer.

2.7.2 Arquitetura da Solução

A VPN foi configurada no Firewall Principal (200.200.200.2), que atua como VPN concentrator. Os clientes remotos ligam-se através da Internet ao endereço público do Firewall, estabelecendo um túnel IPSec encriptado. Após autenticação, é atribuído ao cliente um endereço IP da gama 192.168.20.200-220, correspondente à VLAN 20

(Programação), permitindo acesso transparente aos recursos internos como se o utilizador estivesse fisicamente no escritório.
Para simular o cenário de acesso remoto, foi criada uma rede adicional (100.100.100.0/24) ligada à interface GigabitEthernet0/1 do ISP, representando a ligação doméstica de um programador remoto.

2.7.3 Configuração Implementada

A implementação da VPN exigiu a ativação do módulo de segurança (securityk9) no Firewall Principal e a configuração de múltiplos componentes do protocolo IPSec. Em primeiro lugar, foi ativado o modelo AAA (Authentication, Authorization, Accounting) para gestão centralizada de autenticação e autorização dos utilizadores VPN.
Foi definida uma *pool* de endereços IP (poolVPN) com a gama 192.168.20.200 a 192.168.20.220, dentro da sub-rede da VLAN de Programação. Foram criados três utilizadores correspondentes aos programadores da empresa: pedro.dev, sara.code e bruno.web.
A política ISAKMP (Fase 1) foi configurada com encriptação AES-256, hash SHA, autenticação por chave pré-partilhada e grupo Diffie-Hellman 5, com um lifetime de 3600 segundos. O grupo de clientes (GroupVPN) foi associado à pool de endereços e à chave de grupo.
Para a Fase 2, foi definido o transform set (setVPN) com ESP-AES e ESP-SHA-HMAC, e criado um dynamic crypto map (DynamicVPN) com reverse-route ativado. O static crypto map (StaticMap) foi configurado com as listas de autenticação e autorização AAA e aplicado na interface externa (GigabitEthernet0/0) do Firewall.
As ACLs da interface INTERNET-IN foram atualizadas para permitir o tráfego dos protocolos VPN: UDP 500 (ISAKMP), UDP 4500 (NAT-T) e ESP (protocolo 50).

2.7.4 Testes de Funcionamento

Para validar a solução, foi utilizado um laptop (Laptop6) ligado à rede simulada do ISP (100.100.100.0/24), representando um programador a trabalhar remotamente. O teste consistiu em estabelecer a ligação VPN através do cliente integrado no Packet Tracer e verificar a conectividade com os recursos internos.

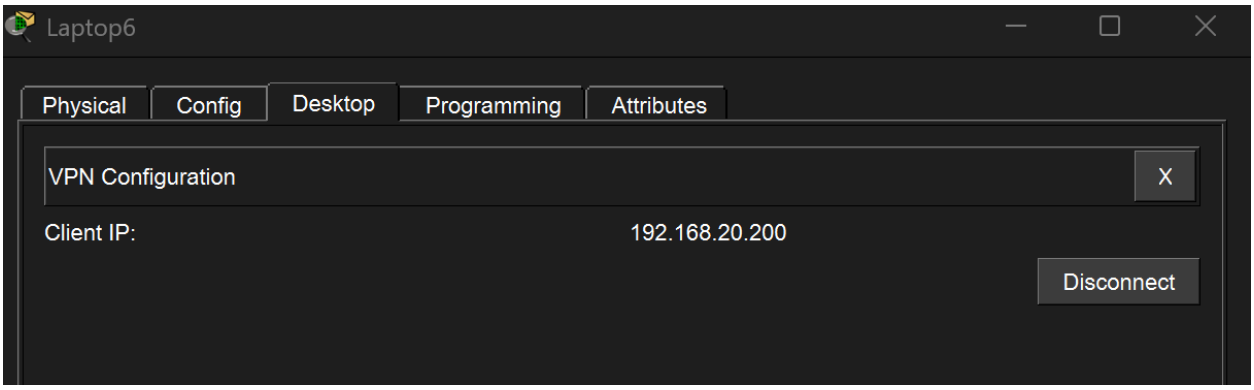


Figura 7 — Ligação VPN estabelecida com sucesso, com atribuição de IP da pool VPN.

Conforme demonstrado na figura, a ligação VPN foi estabelecida com sucesso, tendo sido atribuído um endereço IP ao cliente remoto, confirmando a autenticação e a atribuição de endereço a partir da pool configurada.

```
Pinging 192.168.20.2 with 32 bytes of data:

Reply from 200.200.200.2: bytes=32 time<1ms TTL=254
Reply from 200.200.200.2: bytes=32 time<1ms TTL=254
Reply from 200.200.200.2: bytes=32 time<1ms TTL=254
Reply from 200.200.200.2: bytes=32 time=1ms TTL=254

Ping statistics for 192.168.20.2:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
Approximate round trip times in milli-seconds:
    Minimum = 0ms, Maximum = 1ms, Average = 0ms

C:\>ping 192.168.40.10

Pinging 192.168.40.10 with 32 bytes of data:

Reply from 200.200.200.2: bytes=32 time<1ms TTL=126
Reply from 200.200.200.2: bytes=32 time<1ms TTL=126
Reply from 200.200.200.2: bytes=32 time<1ms TTL=126
Reply from 200.200.200.2: bytes=32 time<1ms TTL=126
```

Figura 8 — Teste de conectividade do cliente VPN para servidores internos.

Os testes de conectividade confirmaram que o cliente VPN consegue aceder aos servidores do Data Center, validando que o túnel IPSec está funcional e que as rotas estão corretamente configuradas.

2.7.5 Resumo da Configuração VPN

Parâmetro	Valor
Protocolo	IPSec (IKEv1)
Encriptação	AES-256
Hash	SHA
Autenticação	Pre-Shared Key + AAA Local
Grupo DH	5
VPN Server	200.200.200.2 (Firewall Principal)
Pool de IPs	192.168.20.200 - 192.168.20.220
VLAN de destino	VLAN 20 (Programação)
Utilizadores	pedro.dev, sara.code, bruno.web

Group Name	GroupVPN
Interface Crypto Map	GigabitEthernet0/0

Tabela 5 — Resumo da configuração VPN implementada.

A implementação desta VPN de acesso remoto constitui uma funcionalidade adicional ao projeto, demonstrando a capacidade de estender de forma segura o perímetro da rede empresarial para utilizadores remotos, mantendo os mesmos níveis de acesso e segurança que teriam fisicamente no escritório.

3. Segurança da Infraestrutura de Rede

A segurança da infraestrutura foi implementada em múltiplas camadas, seguindo o princípio de defesa em profundidade. Foram aplicadas ACLs no Firewall e nos Core Switches, hardening em todos os equipamentos e port security nos switches de acesso.

3.1 ACLs e Políticas de Firewall

As Access Control Lists foram implementadas com base no princípio de least privilege, ou seja, apenas o tráfego estritamente necessário é permitido. Foram definidas três ACLs distintas no Firewall Principal, cada uma aplicada na interface correspondente à sua zona de origem.

A ACL INTERNET-IN, aplicada na interface voltada para o ISP, permite apenas o acesso aos serviços públicos da DMZ (HTTP, HTTPS, DNS, SMTP, POP3) e bloqueia qualquer tentativa de acesso à rede interna. A ACL INTERNA-IN controla o tráfego originado nos departamentos, definindo que zonas cada departamento pode aceder. A ACL DMZ-IN restringe o tráfego da DMZ, permitindo apenas o envio de logs para os servidores de monitorização (Wazuh e ELK Stack) e a consulta DNS interna.

Adicionalmente, foi detetado durante os testes que o tráfego entre VLANs internas não passava pelo Firewall (sendo encaminhado diretamente pelos Core Switches), o que exigiu a criação de uma ACL específica nos Core Switches para bloquear o acesso do departamento de RH à DMZ.

Origem	Destino	Resultado	Justificação
Internet	DMZ (serviços)	**Permitido**	Serviços públicos (HTTP, DNS, Mail)
Internet	Rede Interna	**Bloqueado**	Proteção da rede corporativa
RH (VLAN 10)	DMZ	**Bloqueado**	Sem necessidade funcional de acesso
Programação (VLAN 20)	DMZ	**Permitido**	Necessidade de deploy e gestão de sites
Suporte (VLAN 30)	DMZ	**Permitido**	Suporte técnico e manutenção
Todos os internos	Internet	**Permitido**	Navegação via PAT
DMZ	DC (logs)	**Permitido**	Envio de logs para Wazuh e ELK Stack

DMZ	Rede Interna	**Bloqueado**	Isolamento da DMZ comprometida

Tabela 6 — Políticas de segurança implementadas e respetiva justificação.

```
C:\>ping 192.168.50.10

Pinging 192.168.50.10 with 32 bytes of data:

Reply from 192.168.10.2: Destination host unreachable.
Reply from 192.168.10.2: Destination host unreachable.
Reply from 192.168.10.2: Destination host unreachable.
Reply from 192.168.10.2: Destination host unreachable.

Ping statistics for 192.168.50.10:
    Packets: Sent = 4, Received = 0, Lost = 4 (100% loss),
```

Figura 9 — Teste: *Laptop* do RH bloqueado ao tentar aceder à DMZ (*ping* 192.168.50.10 — *Destination host unreachable*).

```
Cisco Packet Tracer PC Command Line 1.0
C:\>ping 192.168.50.10

Pinging 192.168.50.10 with 32 bytes of data:

Reply from 192.168.50.10: bytes=32 time<1ms TTL=127
Reply from 192.168.50.10: bytes=32 time<1ms TTL=127
Reply from 192.168.50.10: bytes=32 time<1ms TTL=127
Reply from 192.168.50.10: bytes=32 time<1ms TTL=127

Ping statistics for 192.168.50.10:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
Approximate round trip times in milli-seconds:
    Minimum = 0ms, Maximum = 0ms, Average = 0ms

C:\>
```

Figura 10 — Teste: *Laptop* da Programação com acesso à DMZ (*ping* 192.168.50.10 — *Reply*).

As Figuras 9 e 10 demonstram o correto funcionamento das ACLs. O departamento de RH não consegue aceder à DMZ (conforme a política definida), enquanto o departamento de Programação tem acesso permitido para efeitos de desenvolvimento e gestão.

3.2 Fortalecimento da Segurança dos Equipamentos

Foi aplicado um conjunto de medidas de hardening transversal a todos os equipamentos de rede, visando reduzir a superfície de ataque e garantir a integridade do acesso administrativo.

Medida	Descrição
Acesso SSH	Ativado com chaves RSA 2048 bits; Telnet desativado em todas as linhas VTY
Autenticação local	Username e password encriptada (enable secret) em todos os equipamentos
Timeout de sessão	5 minutos de inatividade na consola e VTY
Banner MOTD	Mensagem de aviso legal sobre acesso restrito e monitorização
Encriptação de passwords	service password-encryption ativado em todos os equipamentos
Portas não utilizadas	Desativadas (shutdown) em todos os switches de acesso
Native VLAN	Alterada de VLAN 1 para VLAN 99 em todos os trunks (prevenção VLAN hopping)

Tabela 7 — Medidas de hardening aplicadas aos equipamentos de rede.

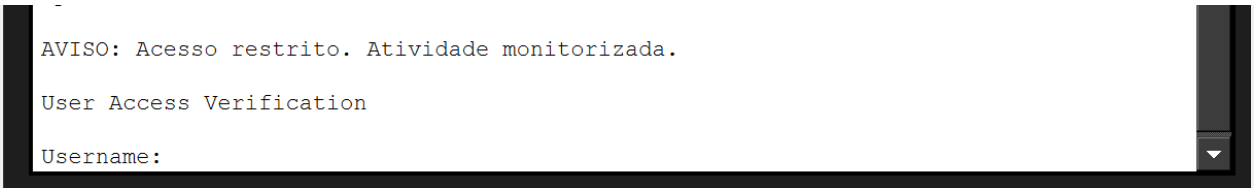


Figura 11 — Banner MOTD ao aceder a um equipamento de rede via consola.

A Figura 8 mostra que o acesso administrativo requer autenticação e que o banner de aviso legal é apresentado antes do login, em conformidade com as boas práticas de segurança.

3.3 Port Security

Nos switches de acesso dos departamentos (SW-RH, SW-Prog e SW-Suporte) foi configurado port security nas portas utilizadas pelos utilizadores finais.
Esta funcionalidade limita o número máximo de endereços MAC por porta a dois, utiliza o modo sticky para aprender dinamicamente os MACs legítimos e define a ação shutdown em caso de violação, desativando automaticamente a porta caso seja detetado um dispositivo não autorizado.

```
SW-RH>ena
Password:
SW-RH#show por
SW-RH#show port-security
Secure Port MaxSecureAddr CurrentAddr SecurityViolation Security Action
               (Count)       (Count)         (Count)
--------------------------------------------------------------------
        Fa0/2        2          1                 0         Shutdown
        Fa0/3        2          1                 0         Shutdown
----------------------------------------------------------------------
SW-RH#
```

Figura 12 — Resultado do comando show port-security no SW-RH.

A Figura 9 confirma que o port security está ativo nas portas Fa0/2 e Fa0/3, com o máximo de 2 endereços Media Access Control (MAC) e a ação de shutdown configurada, prevenindo ataques de MAC flooding e ligações não autorizadas.

3.4 Centralização de Logs (Syslog)

Para complementar as medidas de segurança implementadas, foi configurado um sistema de centralização de logs baseado no protocolo Syslog. O servidor LOG-ELK Stack (192.168.40.12), localizado no Data Center (VLAN 40), foi designado como ponto central de recolha de todos os registos gerados pelos equipamentos de rede, permitindo a monitorização, análise e correlação de eventos de segurança num único local.
O serviço Syslog foi ativado no servidor através da interface gráfica do Packet Tracer (Services → Syslog → ON). Nos equipamentos de rede (Firewall Principal, Core-SW1, Core-SW2 e switches de acesso), foi configurado o envio de logs para o servidor com os seguintes comandos:

```
logging host 192.168.40.12
logging on
service timestamps log datetime msec
service timestamps debug datetime msec
```

O comando logging host define o endereço IP do servidor Syslog de destino. O logging on ativa o envio de mensagens e os service timestamps adicionam carimbos temporais com precisão de milissegundos a todas as mensagens, essencial para a correlação cronológica de eventos entre múltiplos equipamentos.

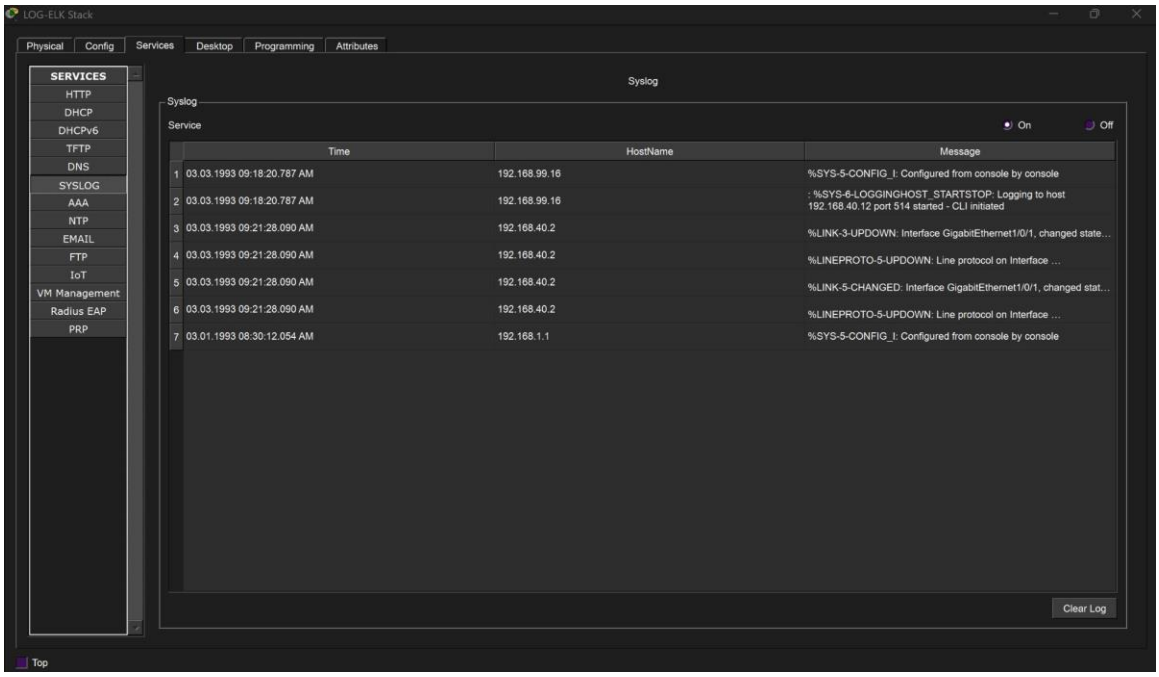


Figura 13 — Servidor LOG-ELK Stack a receber logs via Syslog dos equipamentos de rede.

Conforme demonstrado na figura, o servidor Syslog está a receber com sucesso as mensagens dos equipamentos de rede, incluindo eventos de configuração (%SYS-5-CONFIG_I), ativação do serviço de logging (%SYS-6-LOGGINGHOST_STARTSTOP) e alterações de estado das interfaces (%LINK-3-UPDOWN, %LINEPROTO-5-UPDOWN, %LINK-5-CHANGED). Esta centralização permite a deteção de anomalias, análise forense após incidentes e cumprimento de requisitos de auditoria de segurança.

4. Servidores Data Center

4.1 Diagrama Arquitetura

O Data Center da CodeSecure, Lda. Aloja os servidores centrais da infraestrutura, todos posicionados na VLAN 40 (192.168.40.0/24). A figura seguinte apresenta uma visão geral da arquitetura dos servidores implementados e os respetivos fluxos de comunicação entre si.
Os equipamentos de rede geridos no Cisco Packet Tracer (routers e switches) enviam os seus registos de atividade para o servidor ELK Stack via protocolo Syslog, onde são centralizados e indexados para análise. O Windows Server 2019, o servidor Ubuntu com Samba, a RedHat VM, o servidor ubuntu com Podman e o servidor Drupal da DMZ comunicam diretamente com o Wazuh SIEM (setas azuis), permitindo a centralização dos logs de segurança de todos os sistemas. A linha vermelha representa o fluxo de

logs dos equipamentos de rede para o ELK Stack, responsável pela sua agregação e visualização através do Kibana.

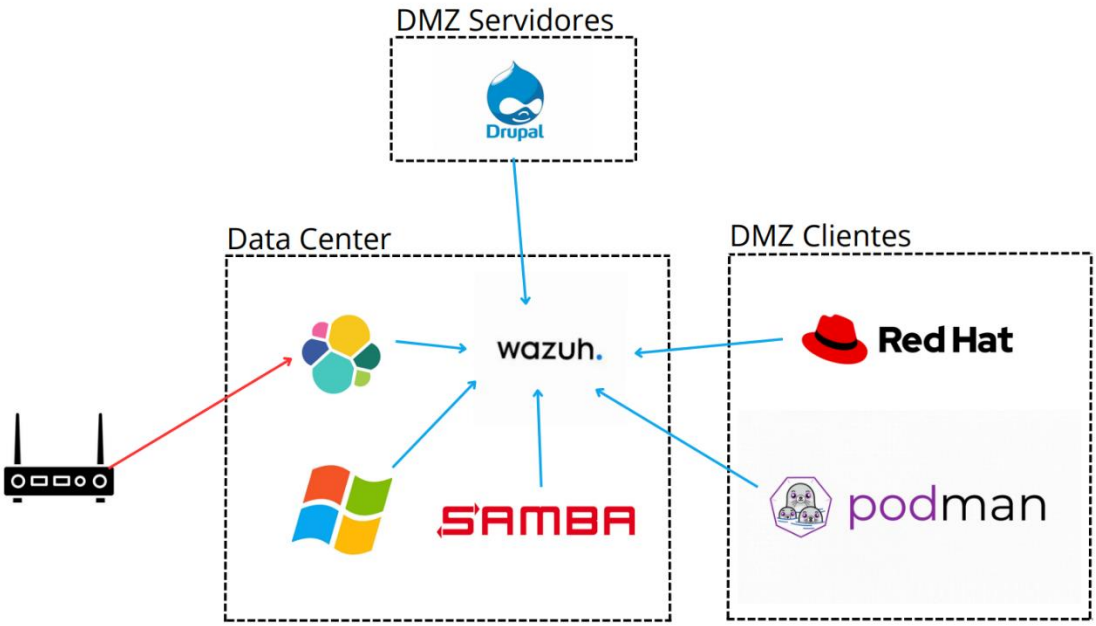


Figura 14 – Arquitetura e comunicação entre os servidores

4.2 Servidor de Partilha de Ficheiros (Ubuntu Server + Samba)

Para dar resposta à necessidade de partilha de ficheiros entre os departamentos da CodeSecure, foi implementado um servidor dedicado baseado em Ubuntu Server 22.04 LTS com o serviço Samba. Este servidor foi posicionado na VLAN 40 (Data Center) e configurado com partilhas segmentadas por departamento.

4.2.1 Criação e Configuração da Máquina Virtual

A máquina virtual foi criada no Oracle VirtualBox com as seguintes especificações: 4 GB de RAM, 2 CPUs, disco de 30 GB Infraestrutura de Desktop Virtual (VDI), dinamicamente alocado) e adaptador de rede em modo Internal Network. O sistema operativo escolhido foi o Ubuntu Server 22.04.5 LTS, pela sua estabilidade, suporte de longo prazo e ampla documentação.
Durante a instalação foi definido o hostname samba-server e foi ativado o serviço OpenSSH para permitir acesso remoto seguro. Não foi instalado ambiente gráfico, em conformidade com as boas práticas para servidores em ambientes de produção.

4.2.2 Configuração de Rede

Após a instalação, foi configurado um endereço IP estático através do Netplan, em conformidade com o esquema de endereçamento definido para o Data Center:

Parâmetro	Valor
IP Address	192.168.40.13/24
Default Gateway	192.168.40.1
DNS Server	192.168.40.10 (AD-DC01)
Domínio de pesquisa	codesecure.local

Tabela 8 — Configuração de rede do servidor Samba.

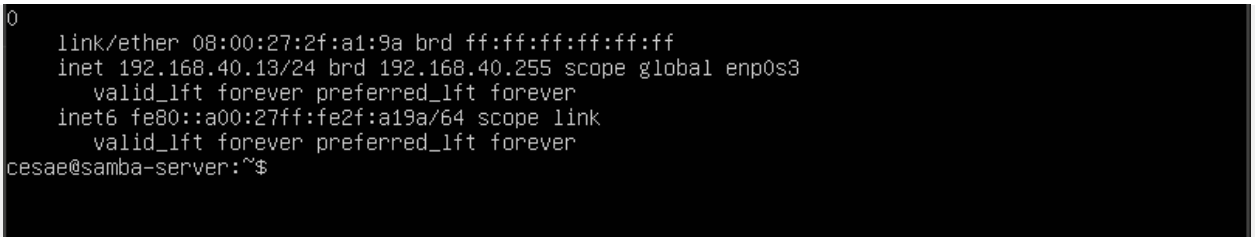


Figura 14 — Resultado do comando ip a no servidor Samba, mostrando o IP 192.168.40.13.

4.2.3 Instalação e Configuração do Samba

O Samba foi instalado e configurado no modo standalone server com autenticação por utilizador (security = user). Foram criadas quatro partilhas de rede, cada uma associada a um departamento específico:

Partilha	Caminho	Acesso Restrito	Permissões
RH	/srv/samba/rh	Grupo rh	Leitura + Escrita (770)
Programacao	/srv/samba/programacao	Grupo programacao	Leitura + Escrita (770)
Suporte	/srv/samba/suporte	Grupo suporte	Leitura + Escrita (770)
Comum	/srv/samba/comum	Todos os grupos	Leitura + Escrita (775)

Tabela 9 — Partilhas Samba configuradas e respetivas permissões.

A configuração do Samba impede que utilizadores de um departamento acedam às partilhas de outros departamentos, através da diretiva “valid users” que restringe o acesso ao grupo correspondente. A partilha Comum é a única acessível por todos os utilizadores autenticados, servindo como espaço de troca de ficheiros interdepartamental.
Por questões de segurança, foi desativado o protocolo Server Message Block (SMB), mais concretamente a versão 1 (SMBv1), permitindo apenas SMB2 e SMB3, prevenindo vulnerabilidades conhecidas como o EternalBlue (CVE-2017-0144).

4.2.4 Grupos, Utilizadores e Permissões

Foram criados três grupos no sistema Linux, correspondentes aos departamentos da empresa, e nove utilizadores de teste distribuídos uniformemente:

Utilizador	Grupo	Departamento	Acesso às Partilhas
maria.silva	rh	Recursos Humanos	RH + Comum
joao.costa	rh	Recursos Humanos	RH + Comum
ana.santos	rh	Recursos Humanos	RH + Comum
pedro.dev	programacao	Programação	Programacao + Comum
sara.code	programacao	Programação	Programacao + Comum
bruno.web	programacao	Programação	Programacao + Comum
luis.tech	suporte	Suporte Técnico	Suporte + Comum
carla.help	suporte	Suporte Técnico	Suporte + Comum
tiago.fix	suporte	Suporte Técnico	Suporte + Comum

Tabela 10 — Utilizadores criados e respetivos acessos.

4.2.5 Testes de Acesso às Partilhas

Foram realizados testes para validar o correto funcionamento das permissões de acesso às partilhas Samba. O primeiro teste consistiu em verificar que um utilizador do departamento de RH consegue aceder à partilha Comum com sucesso.

```
cesae@samba-server:~$ smbclient //localhost/Comum -U maria.silva
Password for [CODESECURE\maria.silva]:
Try "help" to get a list of possible commands.
smb: \>
```

Figura 15 — Utilizador maria.silva a aceder com sucesso à partilha Comum

A Figura 15 confirma que o utilizador maria.silva (grupo RH) consegue aceder à partilha Comum, conforme esperado.
O segundo teste validou que um utilizador não consegue aceder a uma partilha de outro departamento. Foi tentado o acesso da utilizadora maria.silva (RH) à partilha Programacao, tendo sido obtida uma negação de acesso.

```
cesae@samba-server:~$ smbclient //localhost/Programacao -U maria.silva
Password for [CODESECURE\maria.silva]:
tree connect failed: NT_STATUS_ACCESS_DENIED
cesae@samba-server:~$ _
```

Figura 16 — Demonstração do utilizador maria.silva sem acesso à partilha Programacao

A Figura 16 demonstra que as permissões estão corretamente implementadas, impedindo o acesso cruzado entre departamentos.
Foi igualmente testada a listagem de todas as partilhas disponíveis no servidor:

```
cesae@samba-server:~$ smbclient -L localhost -U maria.silva
Password for [CODESECURE\maria.silva]:

        Sharename       Type      Comment
        ---------       ----      -------
        RH              Disk      Partilha Recursos Humanos
        Programacao     Disk      Partilha Programacao
        Suporte         Disk      Partilha Suporte Tecnico
        Comum           Disk      Partilha Comum - Todos os Departamentos
        IPC$            IPC       IPC Service (CodeSecure File Server)
SMB1 disabled -- no workgroup available
cesae@samba-server:~$ _
```

Figura 17 — Listagem das partilhas disponíveis.

A Figura 17 mostra as quatro partilhas configuradas (RH, Programacao, Suporte e Comum), confirmando que a configuração do Samba está completa e funcional.

4.2.6 Hardening do Servidor

Foram aplicadas diversas medidas de hardening no servidor Ubuntu para reduzir a superfície de ataque e reforçar a segurança:

Medida	Descrição
UFW Firewall	Política deny all incoming; permitido apenas SSH, Samba e sub-redes internas
Fail2Ban	Proteção contra ataques de força bruta ao SSH
SSH Hardening	Login root desativado; apenas acesso por utilizador local
Protocolo Samba	Apenas SMB2/SMB3 permitidos; SMBv1 desativado (prevenção EternalBlue)
Syslog Forwarding	Logs enviados para ELK Stack (192.168.40.12) via porta 5514/UDP

Tabela 11 — Medidas de hardening aplicadas ao servidor Ubuntu.

```
cesae@samba-server:~$ sudo ufw status
Status: active
cesae@samba-server:~$ _
```

Figura 18 — Estado do firewall UFW (sudo ufw status).

```
cesae@samba-server:~$ sudo systemctl status fail2ban.service
● fail2ban.service - Fail2Ban Service
     Loaded: loaded (/usr/lib/systemd/system/fail2ban.service; enabled; preset: enabled)
     Active: active (running) since Thu 2026-02-19 14:14:25 UTC; 2min 27s ago
       Docs: man:fail2ban(1)
   Main PID: 1390 (fail2ban-server)
      Tasks: 5 (limit: 4603)
     Memory: 24.4M (peak: 24.9M)
        CPU: 386ms
     CGroup: /system.slice/fail2ban.service
             └─1390 /usr/bin/python3 /usr/bin/fail2ban-server -xf start

fev 19 14:14:25 samba-server systemd[1]: Started fail2ban.service - Fail2Ban Service.
fev 19 14:14:25 samba-server fail2ban-server[1390]: 2026-02-19 14:14:25,413 fail2ban.configreader   [1390]: WARNING 'allowipv6' not defined in 'Definition'. Us>
fev 19 14:14:25 samba-server fail2ban-server[1390]: Server ready
lines 1-14/14 (END)
```

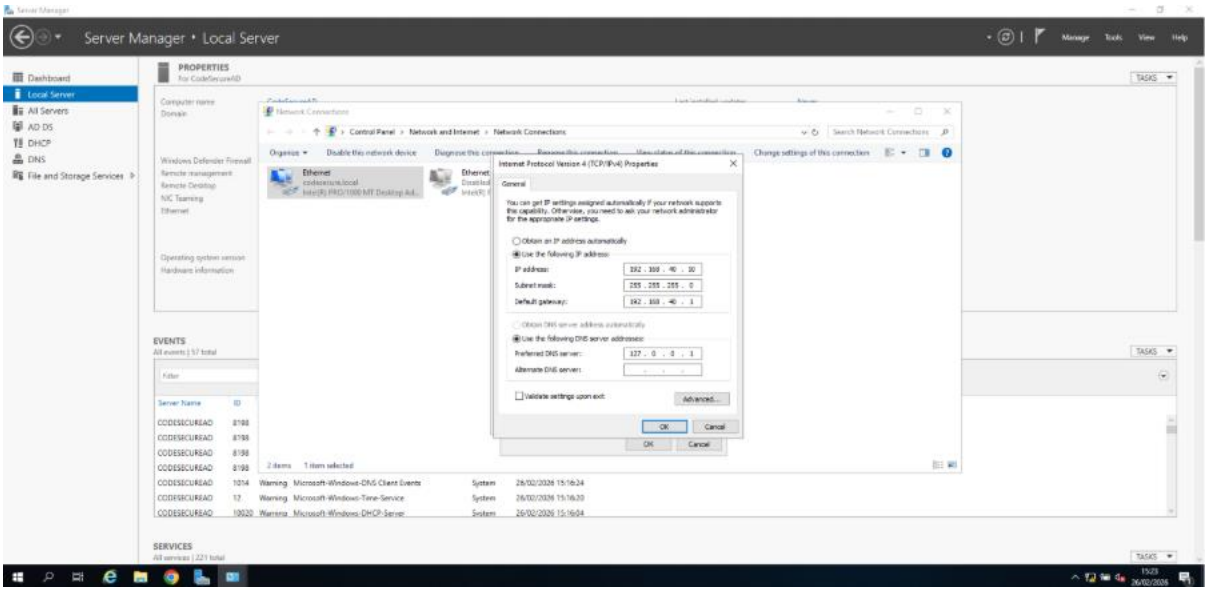
Figura 19 — Estado do serviço Fail2Ban (sudo systemctl status fail2ban).

As Figuras 18 e 19 confirmam que o firewall está ativo com as regras definidas e que o Fail2Ban está em funcionamento, protegendo o servidor contra tentativas de acesso não autorizado.

4.3 Windows Server

No âmbito do projeto CodeSecure, Lda., a infraestrutura implementada no Data Center (VLAN 40) assenta num modelo de defesa em profundidade, onde o Windows Server 2019 e o Wazuh Server desempenham papéis centrais e complementares na gestão e proteção da rede corporativa.

O Windows Server 2019 atua como o "cérebro" da rede interna, sendo configurado como o Domain Controller do domínio codesecure.local.
O seu papel principal é centralizar a governação de toda a empresa através de três serviços críticos:



Figuras 20 - Propriedades do Servidor AD-DC01 e Configurações de IP.

Active Directory Domain Services (AD DS): Gere de forma centralizada as identidades e permissões, organizando a empresa em Unidades Organizacionais (OUs) para os departamentos de RH, Programação, Suporte e Administração.
A segurança deste servidor é reforçada através de *Group Policy Objects* (GPOs), que impõem políticas de passwords complexas e bloqueio de conta após tentativas falhadas, além de medidas de hardening como a desativação do protocolo SMBv1 (Figura 21) e a ativação de auditorias de login.

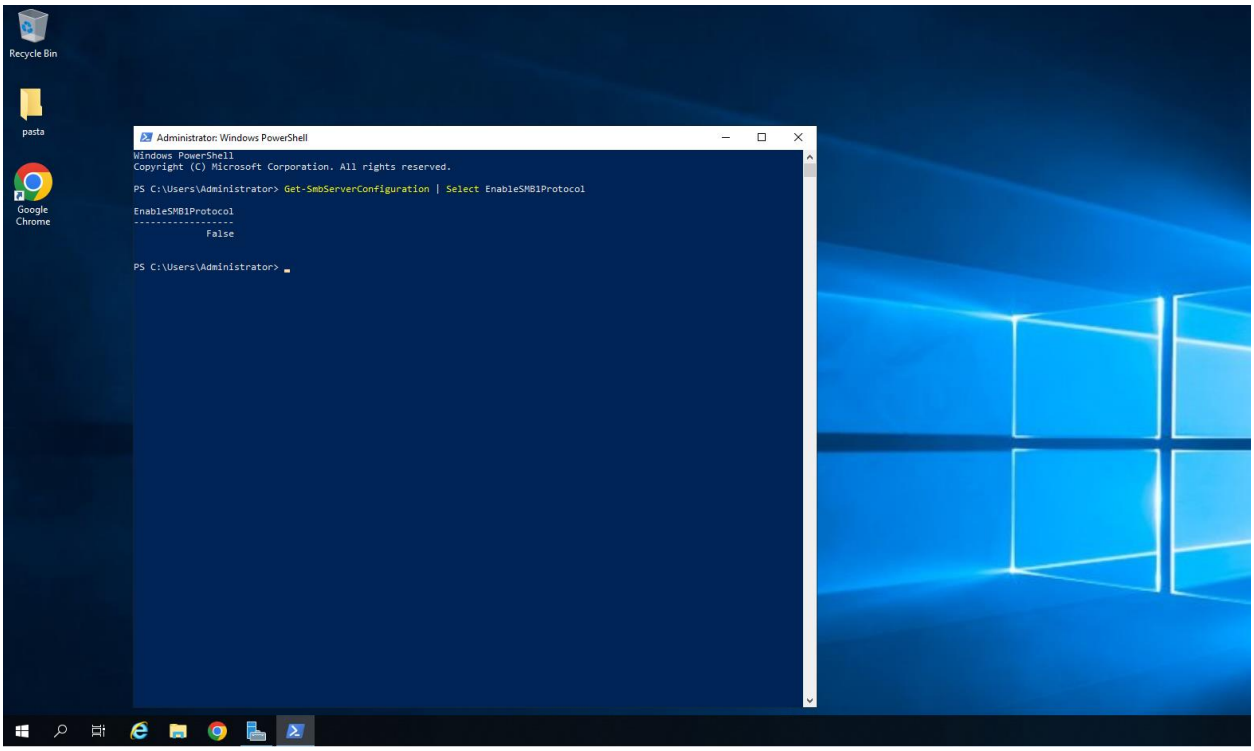


Figura 21 - Confirmação que o protocolo *SMBv1* está desativado.

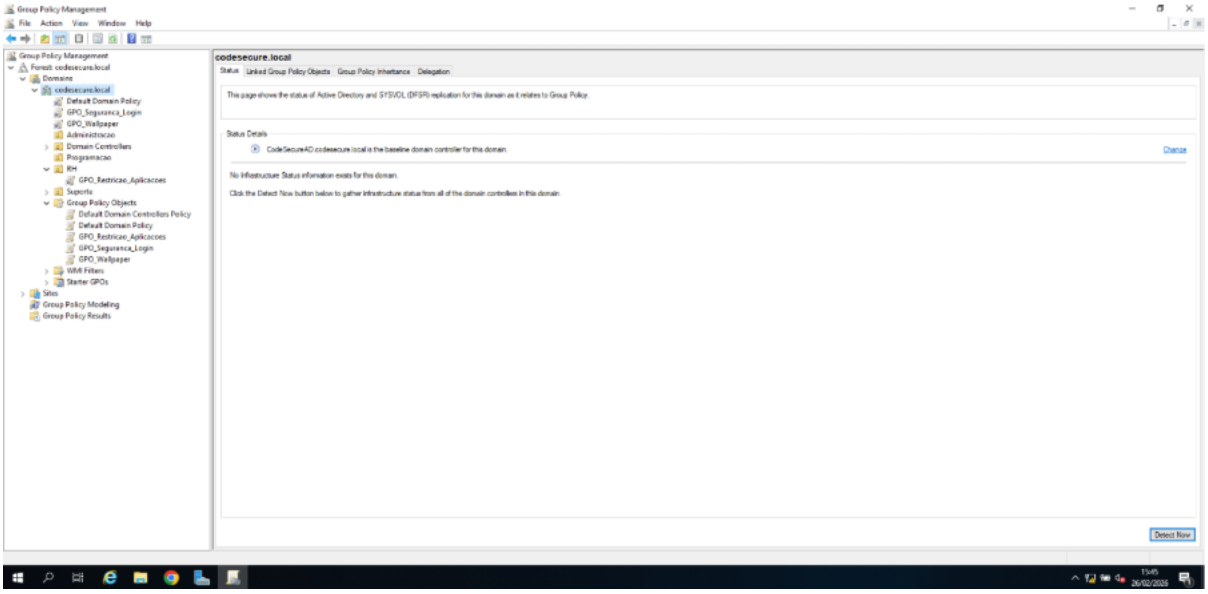


Figura 22 - Estrutura de *Group Policy Objects* (GPOs) aplicadas ao domínio

As principais GPOs implementadas foram password policies para garantir uma password forte e não permanente, auditorias de logon, wallpaper comum a todos os utilizadores do domínio, uso de CTRL + ALT + DELETE ao iniciar sessão e uma mensagem de segurança, account lockout para 3 tentativas de login falhadas, restrição do uso da CMD e powershell para utilizadores não essenciais ao acesso destas

ferramentas e hardening através da desativação do protocolo SMBv1 e ativação da Windows Firewall.

DHCP Server: Garante a conectividade automática dos postos de trabalho nas VLANs 10, 20 e 30, através de âmbitos (scopes) específicos, permitindo que os laptops dos funcionários obtenham endereçamento IP sem intervenção manual.

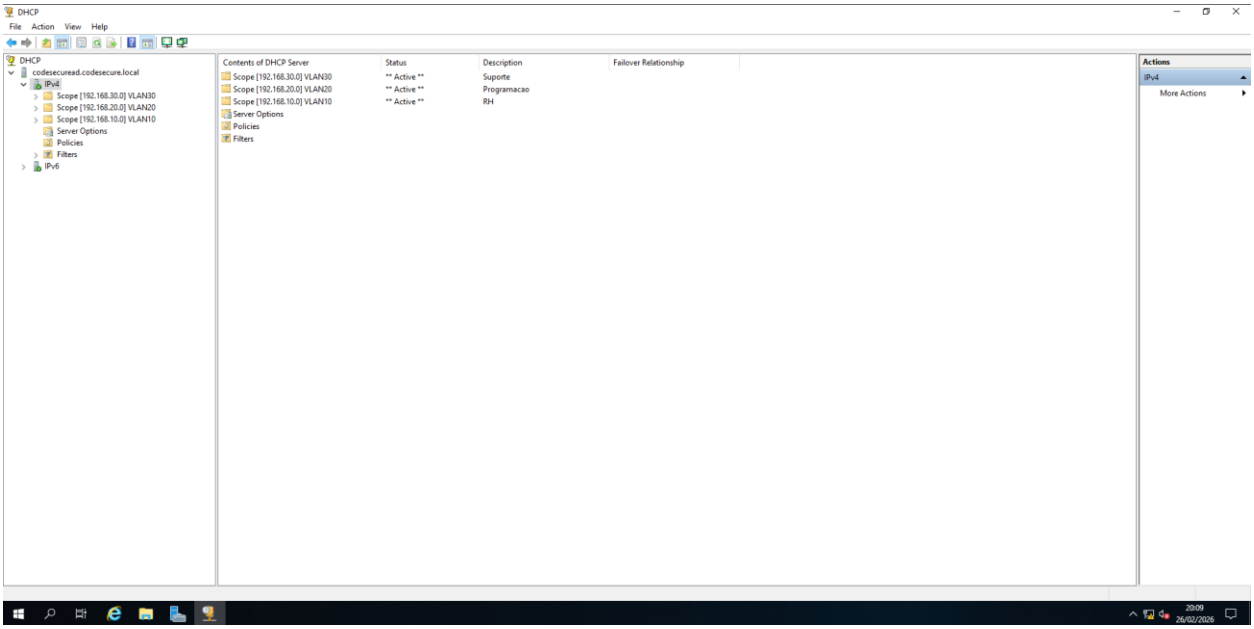


Figura 23 - *Scopes* DHCP para as VLANs 10,20 e 30

DNS *Server*: Fornece a resolução de nomes interna, essencial para que os serviços e servidores (como o servidor de ficheiros Samba ou o SIEM) comuniquem de forma fiável através de registos de zona direta e inversa.

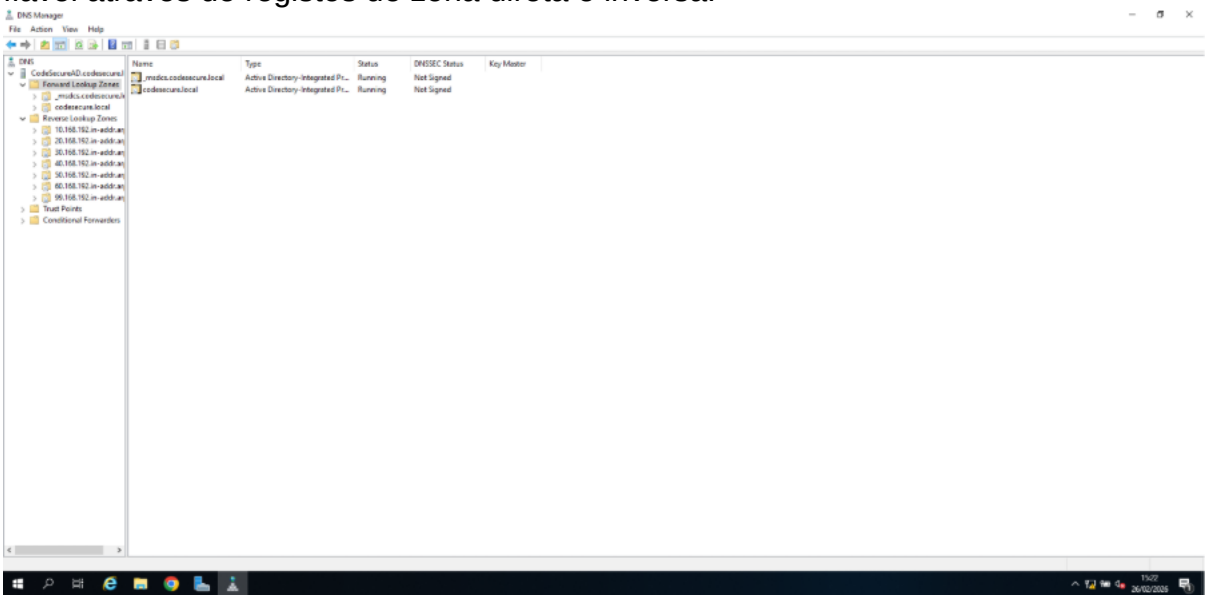


Figura 24 - Configuração de Zonas de Pesquisa Direta e Inversa no DNS Manager.

4.4 Wazuh Server

O Wazuh Server é implementado como a solução de SIEM (Security Information and Event Management) da CodeSecure, funcionando como o centro de vigilância da infraestrutura.
O seu papel é monitorizar a atividade em tempo real através de agentes instalados no Windows Server e nos restantes servidores Linux da equipa (Ubuntu e RedHat).

A infraestrutura conta com cinco agentes ativos, garantindo a cobertura dos ativos críticos, conforme detalhado no inventário técnico abaixo:

ID	Nome do Agente	Endereço IP	Sistema Operativo
002	CodeSecureAD	192.168.40.10	Microsoft Windows Server 2019 Essentials
003	Maquina-Mitigada	192.168.50.13	Debian GNU Linux 13
004	Clients-WebSrvs	192.168.60.10	Debian GNU Linux 13
006	Samba-Server	192.168.40.13	Ubuntu 24.04.4 LTS

Tabela 12 – Agentes Wazuh configurados e respetivas informações pertinentes

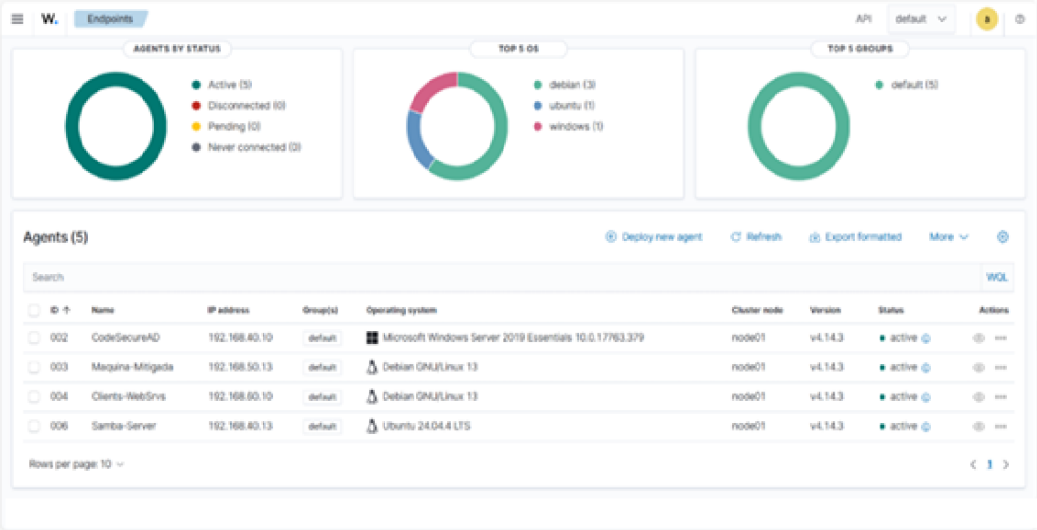


Figura 25 - Inventário de Agentes Ativos no SIEM Wazuh.

As suas funções chave no projeto incluem:

Monitorização de Eventos: Deteção de comportamentos anómalos, tais como tentativas de login falhado (alinhado com a técnica MITRE ATT&CK T1110), scans de portas ou alterações não autorizadas em ficheiros críticos (FIM - File Integrity Monitoring).
As Figura 26 demonstram a deteção de ficheiros modificados ou eliminados.

timestamp	agent.name	rule.description	rule.level	rule.id
Feb 25, 2026 @ 17:21:41.5...	Clients-WebSrvs	File deleted.	7	553
Feb 25, 2026 @ 17:21:38.9...	Clients-WebSrvs	Ficheiro modificado no diretório /root.	7	100300
Feb 25, 2026 @ 17:21:35.6...	Clients-WebSrvs	Ficheiro adicionado ao diretório /root.	7	100301

Figura 26 - *Logs* de *File Integrity Monitoring* (FIM) - Deteção de alterações em ficheiros críticos nos *webservers* dos clientes.

Resposta Ativa (*Active Response*): Capacidade de mitigar ameaças automaticamente (Figura 27), como o bloqueio imediato de endereços *IP* de atacantes após a deteção de um ataque de força bruta (Figura 28).

Feb 25, 2026 @ 15:29:19.6...	Maquina-Mitigada	Host Blocked by firewall-drop Active Response	3	651
Feb 25, 2026 @ 15:29:19.4...	Maquina-Mitigada	IP address found in blocked IP list.	10	100100

Figura 27 – Bloqueio de IP malicioso na Máquina Mitigada

timestamp	agent.name	rule.description	rule.level	rule.id
Feb 25, 2026 @ 15:14:39.5...	Maquina-Mitigada	Host Blocked by firewall-drop Active Response	3	651
Feb 25, 2026 @ 15:14:37.8...	Maquina-Mitigada	PAM: User login failed.	5	5503
Feb 25, 2026 @ 15:14:37.8...	Maquina-Mitigada	PAM: User login failed.	5	5503
Feb 25, 2026 @ 15:14:37.8...	Maquina-Mitigada	sshd: Attempt to login using a non-existent user	5	5710
Feb 25, 2026 @ 15:14:37.8...	Maquina-Mitigada	sshd: Attempt to login using a non-existent user	5	5710
Feb 25, 2026 @ 15:14:37.8...	Maquina-Mitigada	sshd: Attempt to login using a non-existent user	5	5710

Figura 28 - Deteção de Ataques de Força Bruta via *SSH* no Agente Clients-WebSrvs.

Também foi possível integrar o YARA na Máquina Mitigada, cujo é uma ferramenta que permite detetar se um certo ficheiro é um *malware*, e caso verdadeiro, esse ficheiro é imediatamente removido do sistema através do *active response*.
A Figura 29 demonstra a deteção do ficheiro malicioso.

timestamp	agent.name	rule.description	rule.level	rule.id
Feb 25, 2026 @ 15:41:20.7...	Maquina-Mitigada	O ficheiro "/root/eicar.com" corresponde positivamente. Regra YARA: SUSP_Just_EICAR_RID2C24	12	108001
Feb 25, 2026 @ 15:41:19.1...	Maquina-Mitigada	Ficheiro adicionado ao diretório /root.	7	100301

Figura 29 - Integração Wazuh + YARA - Deteção de Ficheiro Malicioso (EICAR).

Visibilidade Centralizada: Através do seu dashboard, fornece uma visão holística da higiene de segurança de toda a rede, permitindo à equipa de TI reagir prontamente a incidentes de segurança.

5. Máquinas Clientes – Servidores de alojamento Web e VMs

5.1 Introdução

No contexto da infraestrutura da CodeSecure, Lda., a empresa disponibiliza serviços de alojamento de *websites* para clientes externos. Para suportar este serviço, foi implementado um servidor dedicado de alojamento *web*, posicionado na DMZ de clientes (VLAN 60), com o endereço IP 192.168.60.10, baseado em Ubuntu Server.
A solução adotada baseia-se na utilização de *containers*, recorrendo ao *Podman* como motor de containerização. O *Podman* é uma alternativa ao *Docker* que não requer um *daemon* em execução com privilégios elevados (*daemonless*), tornando-o mais seguro por *design*. Cada cliente fica isolado no seu próprio *container*, com o seu próprio servidor *web nginx* e os seus ficheiros HTML independentes, eliminando qualquer interferência entre *websites* de clientes distintos.
Foram configurados cinco *containers*, cada um correspondente a um cliente da CodeSecure, simulando um ambiente real de alojamento partilhado com isolamento garantido por containerização.

5.2 Configuração do Servidor

5.2.1 Instalação do Podman

O Podman foi instalado no servidor Ubuntu através do gestor de pacotes *apt*. Após a instalação, foi configurado o ficheiro de registos de imagens em "/etc/containers/registries.conf", de forma a incluir o *Docker Hub* (*docker.io*) como repositório de pesquisa de imagens, permitindo o descarregamento automático da imagem "*nginx:alpine*".

5.2.2 Estrutura de ficheiros dos Clientes

Para cada cliente foi criada uma diretória dedicada em ~/websites/, contendo os respetivos ficheiros HTML do *website*. Esta separação garante o isolamento dos conteúdos entre clientes e facilita a gestão e atualização individual de cada website. A estrutura de diretórias criada foi a seguinte: ~/websites/cliente-a/, ~/websites/cliente-b/, ~/websites/cliente-c/, ~/websites/cliente-d/ e ~/websites/cliente-e/.

5.2.3 Configuração dos Containers

Foi criado um *script bash* ("*start-containers.sh*") que automatiza o lançamento de todos os *containers*. Cada *container* foi iniciado com o comando "*podman run*", utilizando a imagem "*nginx:alpine*", e configurado com os seguintes parâmetros: modo *detached* (-d), nome único por cliente (--name), mapeamento de porta (-p) e volume montado em modo *read-only* (-v) apontando para a diretoria HTML do respetivo cliente.
A tabela seguinte resume a configuração atribuída a cada *container*:

Container	Cliente	Porta	Volume
Web-client-a	Cliente A (Fotografia)	8081	~/websites/cliente-a/
Web-client-b	Cliente B (E-Commerce)	8082	~/websites/cliente-b/

Web-client-c	Cliente C (Vlog)	8083	~/websites/cliente-c/
Web-client-d	Cliente D (Restaurante)	8084	~/websites/cliente-d/
Web-client-e	Cliente E (Agência digital)	8085	~/websites/cliente-e/

Tabela 13 - Configuração dos *containers* Podman por cliente

O volume de cada container foi montado em modo *read-only* (:ro), impedindo que o processo *nginx* dentro do *container* altere os ficheiros do *website*. Esta é uma medida de segurança importante, pois limita o impacto de uma eventual vulnerabilidade do *container* à escrita de ficheiros no *host*.

5.3 Servidor *RedHat*

Para a virtualização de máquinas virtuais (VMs) dos clientes, foi escolhido um servidor com sistema operacional *RedHat Enterprise Linux*. A proposta era que esse servidor servisse como ambiente centralizado para hospedar e gerenciar as VMs, permitindo que cada cliente tivesse seu próprio ambiente isolado e configurável de forma independente.
No total, foi prevista a criação de 14 VMs, uma para cada cliente, de modo a simular um ambiente multiusuário dentro de um mesmo servidor físico.
A ideia central era demonstrar o conceito de virtualização e como um único servidor poderia atender múltiplos clientes, otimizando recursos de *hardware* e simplificando a manutenção.
É importante destacar que nenhuma configuração real de virtualização foi realizada. Ou seja, o servidor *RedHat* não chegou a hospedar efetivamente essas VMs; a abordagem utilizada foi apenas conceitual. O objetivo foi registrar a arquitetura planejada e o potencial de uso do servidor para fins de estudo e documentação, sem implementar de fato o ambiente virtualizado.

5.4 Testes de Funcionamento

5.4.1 Verificação do estado dos Containers

Através do comando "*podman ps*" foi confirmado que os cinco *containers* se encontravam em execução (estado *Up*), com os respetivos mapeamentos de portas ativos. O resultado deste comando confirmou a presença dos *containers* web-client-a, web-client-b, web-client-c, web-client-d e web-client-e, todos com a imagem docker.io/library/nginx:alpine.

```
root@db-cesae:~# podman ps
CONTAINER ID  IMAGE                          COMMAND               CREATED      STATUS         PORTS                   NAMES
a41c1a3cbc06  docker.io/library/nginx:alpine  nginx -g daemon o...  11 days ago  Up 11 seconds  0.0.0.0:8081->80/tcp    web-client-a
3f9862d8c7ea  docker.io/library/nginx:alpine  nginx -g daemon o...  11 days ago  Up 11 seconds  0.0.0.0:8082->80/tcp    web-client-b
7fc4da0be4d7  docker.io/library/nginx:alpine  nginx -g daemon o...  11 days ago  Up 10 seconds  0.0.0.0:8083->80/tcp    web-client-c
9e99d167563c  docker.io/library/nginx:alpine  nginx -g daemon o...  11 days ago  Up 10 seconds  0.0.0.0:8084->80/tcp    web-client-d
fe5e02396a18  docker.io/library/nginx:alpine  nginx -g daemon o...  11 days ago  Up 10 seconds  0.0.0.0:8085->80/tcp    web-client-e
root@db-cesae:~#
```

Figura 30 – Resultado do comando “podman ps” com os cinco *containers* em execução.

5.4.2 Acesso Externo via Browser

Foi verificado o endereço IP atual do servidor através do comando “ip a”, tendo sido identificado o endereço 192.168.60.10 na interface “enp0s3”. Os websites dos cinco clientes ficam acessíveis a partir de qualquer máquina na mesma rede através dos seguintes URLs:

```
http://192.168.60.10:8081 — Cliente A (Fotografia)

http://192.168.60.10:8082 — Cliente B (E-commerce)

http://192.168.60.10:8083 — Cliente C (Vlog)

http://192.168.60.10:8084 — Cliente D (Restaurante)

http://192.168.60.10:8085 — Cliente E (Agência Digital)
```

A Figura 31 apresenta o website criado para o Cliente D.

Figura 31 – Acesso ao Website do Cliente D através do browser.

5.5 Autoarranque dos Containers (*Systemd*)

Para garantir a disponibilidade contínua do serviço de alojamento, foi configurado o autoarranque dos *containers* após reinicialização do servidor. Através do comando *podman generate systemd*, foram gerados automaticamente ficheiros de serviço (.service) para cada *container*, os quais foram colocados em ~/.config/systemd/user/. Desta forma, o *systemd* garante que os cinco *containers* são iniciados automaticamente sempre que o servidor arranca, sem necessidade de intervenção manual, assegurando a continuidade do serviço.

6. Máquina Vulnerável

6.1 Introdução

Foi realizada uma atividade de reconhecimento, enumeração, deteção de vulnerabilidades e análise de riscos sobre um servidor exposto na empresa em questão.
O objetivo principal não foi a exploração destrutiva, mas sim:

- Identificar fragilidades do sistema;
- Avaliar o impacto das vulnerabilidades encontradas;
- Enquadrar as ações realizadas na *framework* MITRE ATT&CK;
- Propor medidas de mitigação e uma nova solução de servidor, mais segura e preparada para monitorização.

Antes de iniciar qualquer atividade, a máquina alvo foi isolada num ambiente controlado, fora da infraestrutura produtiva da empresa, recorrendo a uma rede interna virtual (*host-only*) com o uso da aplicação *VirtualBox*, como é possível verificar na Figura 32.

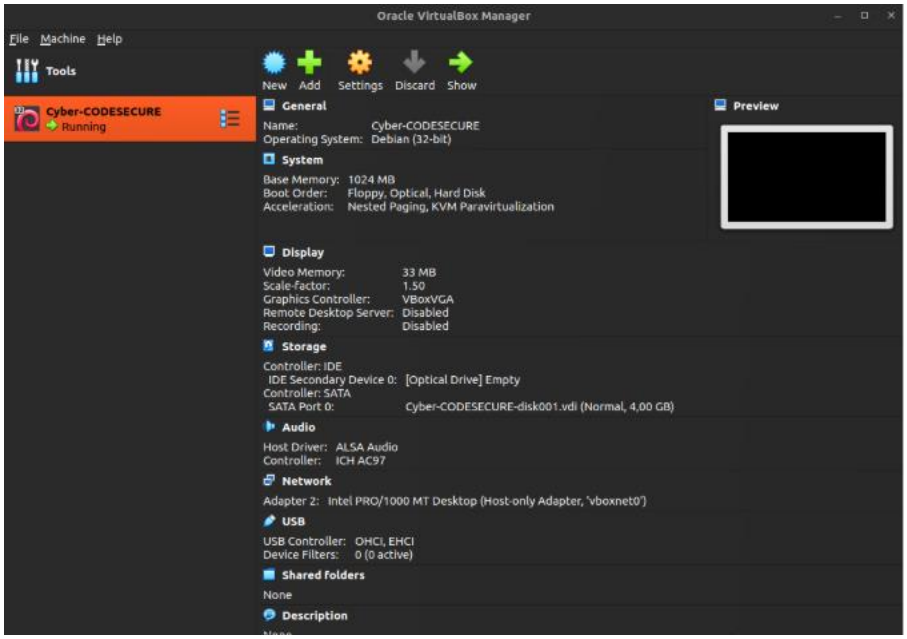


Figura 32 – Isolamento e configuração da máquina no VirtualBox

Este procedimento teve como objetivo evitar impacto em sistemas reais, garantir conformidade com boas práticas de testes de penetração e permitir análise segura e controlada.

6.2 Enumeração de portas e serviços

Foi efetuado um scan de descoberta de *hosts* na rede interna para identificar o endereço IP do sistema ativo através da ferramenta *nmap*, sendo associada a técnica *T1046 – Network Service Discovery* do *MITRE ATT&CK*.
A Figura 33 apresenta o comando *bash* efetuado, juntamente com o resultado, cujo mostra a identificação de 1 endereço IP presente na rede.

```
└─$ nmap -sn 192.168.56.0/24
Starting Nmap 7.80 ( https://nmap.org ) at 2026-02-10 16:52 WET
Nmap scan report for ferrero-laptop (192.168.56.1)
Host is up (0.00036s latency).
Nmap scan report for 192.168.56.103
Host is up (0.00051s latency).
Nmap done: 256 IP addresses (2 hosts up) scanned in 2.39 seconds
```

Figura 33 – Utilização da ferramenta *nmap* para scan da rede

Após a identificação do IP (192.168.56.103), foram realizados dois scans principais.

6.2.1 Scan com a ferramenta nmap

Foi utilizada mais uma vez a ferramenta *nmap*, para a identificação de portas abertas e serviços a correr nas mesmas. Os serviços identificados estão apresentados na Tabela 14.

Porta	Serviço	Versão
22	SSH	OpenSSH 6.0p1
80	HTTP	Apache 2.2.22 / Drupal 7
111	RPCBind	Rpcbind 2-4
57061	RTC Status	RPC #100024

Tabela 14 – Identificação de portas abertas e serviços na máquina alvo

As técnicas MITRE ATT&CK associadas a esta fase são:

- T1046 – *Network Service Discovery*
- T1082 – *System Information Discover*

6.2.2 Scan com a ferramenta Nessus

Para ajudar no reconhecimento de vulnerabilidades, foi utilizada a ferramenta *Nessus* para identificação automática de vulnerabilidades conhecidas. Este scan permitiu

identificar uma quantidade elevada de vulnerabilidades, cujas foram identificadas como críticas, altas e médias.
A Figura 34 apresenta o número de vulnerabilidades identificadas com o *Nessus*.

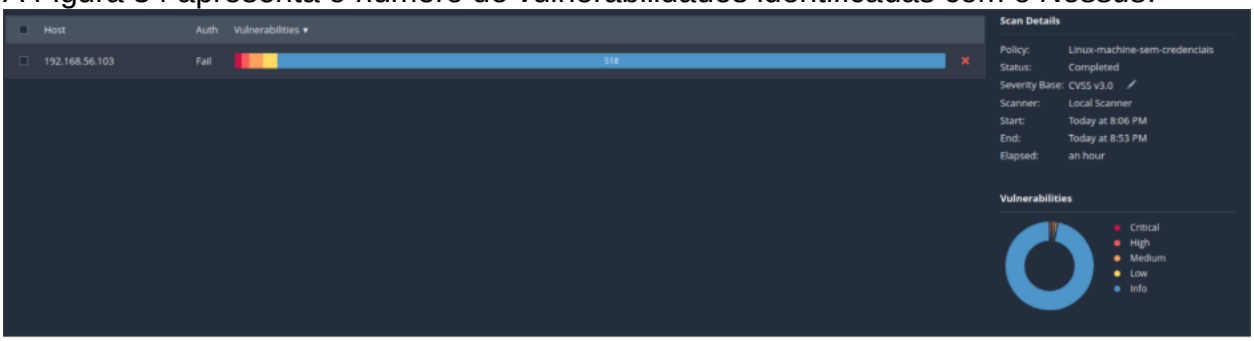


Figura 34 – Resumo do resultado do scan Nessus

6.3 Vulnerabilidades Identificadas

6.3.1 Sistema Operativo

Foram encontradas vulnerabilidades críticas relativamente à versão do sistema operativo da máquina alvo, nomeadamente:

- Debian 7 (*End of Life*)
- Kernel Linux 3.2
- Sem atualizações de segurança

Risco: Crítico
Impacto: Comprometimento total do sistema
Mitigação: Atualizar o sistema operativo para uma versão mais recente, segura e estável

6.3.2 Serviço SSH (Porta 22)

Na porta 22, foi identificado o serviço e versão SSH (*Secure Shell*) à escuta.
A versão e *software* utilizados neste serviço são antigas e estão vulneráveis a alguns ataques e utilizam algoritmos de encriptação fracos, onde um atacante consegues realizar ataques DoS (*Denial of Service)* e desencriptar a comunicação efetuada entre um cliente e o servidor SSH.
A Figura 35 apresenta as vulnerabilidades que o Nessus detetou relativamente ao SSH.

Sev	CVSS	VPR	EPSS	Name	Family	Count
MEDIUM	4.3 *			SSH Weak Algorithms Supported	Misc.	1
LOW	3.7	1.4	0.0307	SSH Server CBC Mode Ciphers Enabled	Misc.	1
LOW	3.7			SSH Weak Key Exchange Algorithms Enabled	Misc.	1
LOW	2.6 *			SSH Weak MAC Algorithms Enabled	Misc.	1
INFO				Backported Security Patch Detection (SSH)	General	1
INFO				OpenSSH Detection	Misc.	1
INFO				SSH Algorithms and Languages Supported	Misc.	1
INFO				SSH Password Authentication Accepted	Service detection	1
INFO				SSH Protocol Versions Supported	General	1
INFO				SSH Server Type and Version Information	Service detection	1
INFO				SSH SHA-1 HMAC Algorithms Enabled	Misc.	1

Figura 35 – Lista de vulnerabilidades detetadas pelo Nessus do SSH

As vulnerabilidades com mais impacto são:

- CVE-2016-6515 – DoS por passwords longas
- CVE-2016-10708 – DoS por pacotes SSH malformados
- Algoritmos fracos:
    - CBC
    - SHA1
    - Diffie-Hellman Group1
    - RC4

Risco: Médio
Impacto: Ataques Man-in-the-middle, Interrupção do serviço
Mitigação: Atualizar o serviço SSH para uma versão mais recente, segura e estável
Técnicas do *MITRE ATT&CK* associadas:

- T1110 – *Brute Force*
- T1499 – *Endpoint Denial of Service*

6.3.3 Serviço HTTP (Porta 80)

Na porta 80 foi identificado um serviço *HTTP* à escuta, disponibilizado através do *Apache HTTP Server*, alojando uma aplicação web baseada no *Drupal* versão 7. Durante a fase de enumeração inicial, foi possível identificar a tecnologia utilizada através de cabeçalhos *HTTP* e da análise de ficheiros públicos acessíveis, como o "*CHANGELOG.txt*" e o "*robots.txt*", os quais confirmaram que o sistema de gestão de conteúdos utilizado era o *Drupal* 7, numa versão desatualizada.
A Figura 36 apresenta a página inicial do serviço *HTTP Drupal 7*.

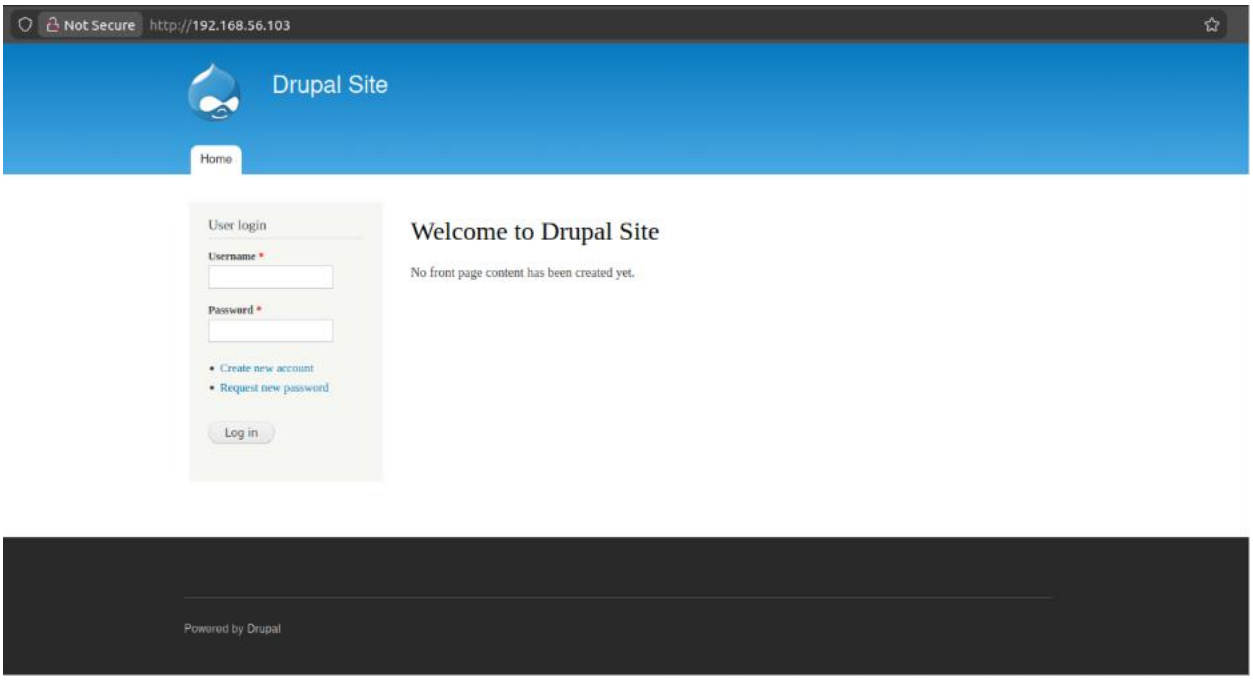


Figura 36 – Página inicial da aplicação web Drupal

Durante a enumeração do serviço web foram identificados diversos indícios de má configuração e exposição de informação sensível, nomeadamente:

- Presença do ficheiro *robots.txt* com múltiplos diretórios sensíveis listados;
- Acesso direto a ficheiros de instalação e documentação ("*INSTALL.txt*", "*CHANGELOG.txt*", "*MAINTAINERS.txt*");
- Diretórios internos do *Drupal* acessíveis publicamente (*/modules*, */themes*, */includes*);
- Utilização de versões antigas de *PHP* e bibliotecas *JavaScript*.

Esta informação facilita o trabalho de um potencial atacante, permitindo-lhe identificar rapidamente:

- A tecnologia utilizada;
- A versão exata do software;
- Superfícies de ataque conhecidas.

Após a enumeração, foi realizado um scan de vulnerabilidades com o *Nessus*, focado no serviço *web*, com o objetivo de identificar falhas conhecidas associadas à versão do *Drupal* e aos componentes subjacentes (*PHP*, bibliotecas *JavaScript* e configuração do servidor *web*).

O *scan* revelou múltiplas vulnerabilidades críticas e altas, muitas das quais amplamente conhecidas e com *exploits* públicos disponíveis, como é possível verificar na Figura 37.

Sev	CVSS	VPR	EPSS	Name	Family	Count
CRITICAL	10.0			PHP Unsupported Version Detection	CGI abuses	1
HIGH	7.5			PHP < 7.3.24 Multiple Vulnerabilities	CGI abuses	1
MEDIUM	5.3			PHP < 7.3.28 Email Header Injection	CGI abuses	1
MEDIUM	5.0 *			PHP expose_php Information Disclosure	Web Servers	1
INFO				PHP Version Detection	Web Servers	1
HIGH	7.5 *	7.4	0.9437	Drupal Database Abstraction API SQLi	CGI abuses	2
INFO				Drupal Software Detection	CGI abuses	1
LOW	2.6 *			Web Server Transmits Cleartext Credentials	Web Servers	1
LOW				Web Server Allows Password Auto-Completion	Web Servers	1
INFO				Web Server Directory Enumeration	Web Servers	1
INFO				Web Server robots.txt Information Disclosure	Web Servers	1
MEDIUM	6.1	5.7	0.323	jQuery 1.2 < 3.5.0 Multiple XSS	CGI abuses : XSS	1
INFO				jQuery Detection	CGI abuses	1

Figura 37 - Lista de vulnerabilidades detetadas pelo Nessus do HTTP, PHP, Drupal

As vulnerabilidades mais relevantes identificadas foram:

- CVE-2014-3704 – *Drupalgeddon*
  - Vulnerabilidade de *SQL Injection* na *API* de abstração de base de dados do *Drupal*;
  - Permite execução remota de código sem autenticação;
- CVE-2018-7600 – *Drupalgeddon 2*
  - Execução remota de código através de formulários mal validados;
- CVE-2018-7602 – *Drupalgeddon 3*
  - Execução remota de código autenticada;
- Versão de *PHP* 5.4, não suportada e com múltiplas vulnerabilidades conhecidas;
- Bibliotecas *jQuery* vulneráveis a ataques *XSS* (*Cross-Site Scripting*);
- Divulgação de informação sensível através de ficheiros acessíveis publicamente.

Risco: Crítico
Impacto: Comprometimento total da aplicação web, acesso não autorizado ao sistema operativo subjacente, possibilidade de movimentação lateral e escalonamento de privilégios na infraestrutura.
Mitigação: Atualizar o *Drupal* para uma versão suportada e segura, atualizar *PHP* e bibliotecas associadas, remover ficheiros de instalação e documentação do ambiente de produção, implementar mecanismos adicionais de proteção (*WAF*, *hardening do Apache*).

Técnicas do MITRE ATT&CK associadas:

- T1190 – *Exploit Public-Facing Application*
- T1059 – *Command and Scripting Interpreter*
- T1083 – *File and Directory Discovery*

6.4 Exploração Segura das Vulnerabilidades

Depois de ser recolhida toda a informação pertinente para o alvo, foi executada uma série de testes de modo a validar as vulnerabilidades expostas

6.4.1 Exploração do serviço SSH

Foi utilizado um exploit referente ao CVE-2016-6515, que permite atacar o serviço SSH e causar um Denial of Service no mesmo, deixando-o completamente inutilizável enquanto o *exploit* corre.

A Figura 38 apresenta o *exploit* em execução, juntamente com o serviço *SSH* do servidor inativo, provando que é possível realizar um *DoS* no serviço *SSH*.

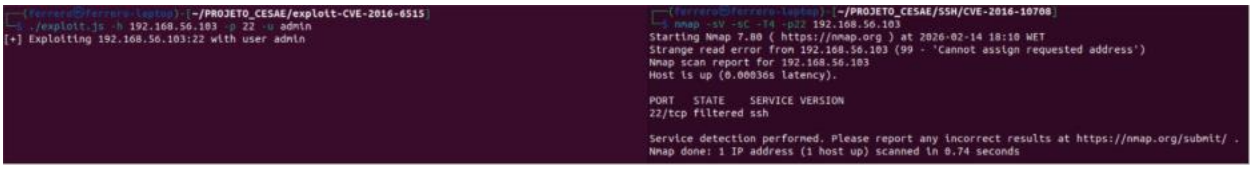


Figura 38 – Execução do exploit relativo ao CVE-2016-6515 e PoC

É possível verificar que com a execução do *exploit*, o serviço aparece como "*filtered*" no scan do *nmap*, o que indica com uma razão forte que o serviço se encontra em baixo.

6.4.2 Exploração do serviço HTTP

A vulnerabilidade CVE-2014-3704, também conhecida como *Drupalgeddon*, permitiu a realização de um ataque de *SQL Injection*, através do qual foi possível manipular a base de dados da aplicação *Drupal*.
Como resultado da exploração:

- Foi possível redefinir a palavra-passe do utilizador administrador;
- Obter acesso administrativo à aplicação web;
- Executar código PHP arbitrário no servidor.

A Figura 39 demonstra a execução do exploit relativo ao CVE-2014-3704 que modificou a password do utilizador "*admin*" para "*admin*", onde a partir daí foi possível realizar o login na aplicação com essas credenciais.

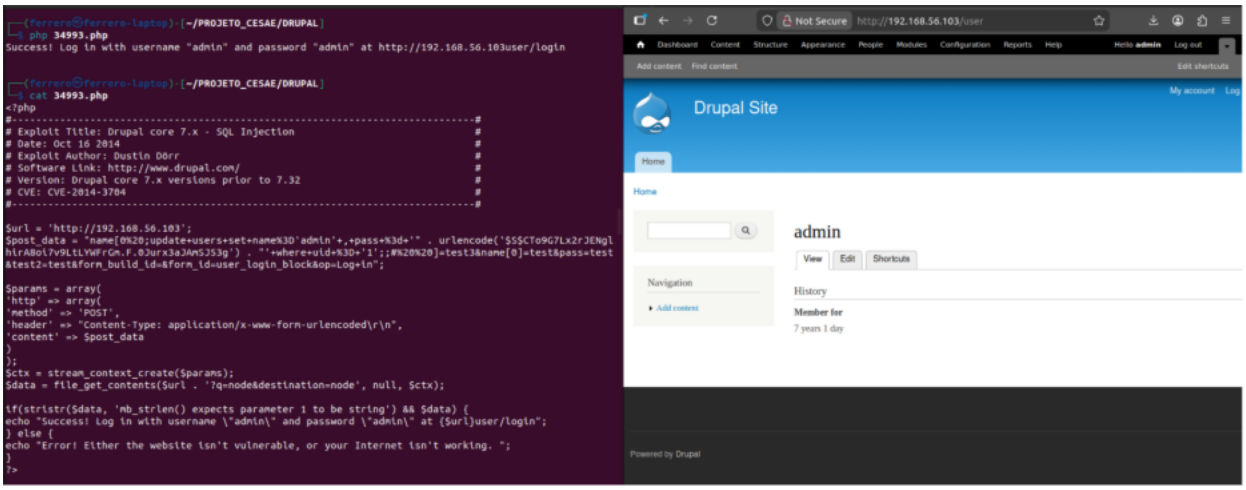


Figura 39 – Execução do exploit com SQLi e login na aplicação com utilizador *admin*

Após a obtenção de privilégios administrativos na aplicação, existem várias maneiras de conseguir acesso não restrito ao servidor através de uma *reverse Shell*. Foi identificado que é possível inserir código PHP malicioso através da edição de conteúdos, mais concretamente, na criação ou modificação de uma "*Basic page*" ou "*Article*" da aplicação *Drupal*, permitindo a execução de comandos no sistema operativo subjacente.
Esta execução ocorreu com os privilégios do utilizador do servidor web (*www-data*), conforme demonstrado pelo comando "*id*" na Figura 40a e na Figura 40b.

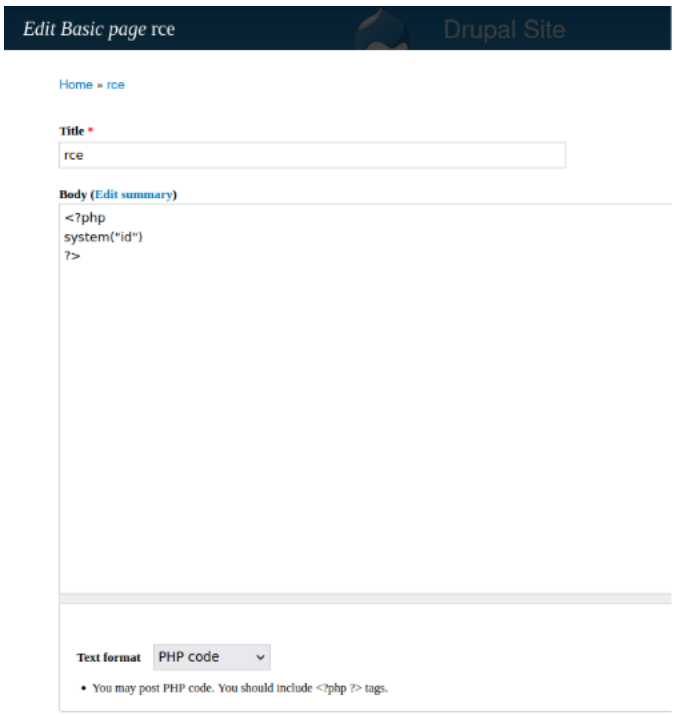


Figura 40a – *Payload* utilizado para *Remote Code Execution*

Figura 40b – *Output* do *payload* da Figura X

Este passo confirmou que a vulnerabilidade permitia *Remote Code Execution* (RCE), o que representa um dos cenários de risco mais elevados num serviço exposto.

Esta técnica foi utilizada para ler o ficheiro */etc/passwd*, cujo contém os nomes de todos os utilizadores do sistema. O código PHP utilizado foi "*<?php system("cat /etc/passwd")>*.

Após verificar todos os utilizadores do sistema, existia um chamado "*flag4*", onde era possível autenticar com *SSH* no sistema, apenas se as credenciais desse utilizador estiverem corretas.

Com este efeito, foi realizado um ataque de *brute force* ao serviço *SSH* colocando como utilizador "*flag4*" e foi utilizado uma lista que contém uma quantidade enorme de palavras-passe mais conhecidas. A ferramenta utilizada para este propósito foi o *hydra*. Foi, com esta ferramenta, possível obter credenciais válidas para o utilizador *flag4*, onde se descobriu através de *brute force* que a palavra-passe do mesmo era "*orange*", como é possível verificar na Figura 41.

Figura 41 – Ataque de *brute force* ao serviço *SSH* com o utilizador *flag4*

A técnica MITRE ATT&CK associada a esta fase é a T1110 – *Brute Force.*

Após o acesso inicial ao sistema como utilizador *flag4*, foi iniciada uma fase de enumeração local, com o objetivo de identificar potenciais vetores de escalada de privilégios.

Durante esta análise, foi identificado o binário "/usr/bin/find" com o bit *Set User ID* (SUID) ativo, permitindo a sua execução com privilégios de *root*, como é possível verificar na Figura 42.

```
flag4@DC-1:/tmp$ find / -type f -perm -04000 -ls 2>/dev/null
  4108   88 -rwsr-xr-x   1 root     root        88744 Dec 10  2012 /bin/mount
  7383   32 -rwsr-xr-x   1 root     root        31104 Apr 13  2011 /bin/ping
  3290   36 -rwsr-xr-x   1 root     root        35200 Feb 27  2017 /bin/su
  7385   36 -rwsr-xr-x   1 root     root        35252 Apr 13  2011 /bin/ping6
  4110   68 -rwsr-xr-x   1 root     root        67704 Dec 10  2012 /bin/umount
 30578   52 -rwsr-sr-x   1 daemon   daemon      50652 Oct  4  2014 /usr/bin/at
  5033   36 -rwsr-xr-x   1 root     root        35892 Feb 27  2017 /usr/bin/chsh
  5036   48 -rwsr-xr-x   1 root     root        45396 Feb 27  2017 /usr/bin/passwd
  3300   32 -rwsr-xr-x   1 root     root        30880 Feb 27  2017 /usr/bin/newgrp
  5032   44 -rwsr-xr-x   1 root     root        44564 Feb 27  2017 /usr/bin/chfn
  5035   68 -rwsr-xr-x   1 root     root        66196 Feb 27  2017 /usr/bin/gpasswd
 31155   84 -rwsr-sr-x   1 root     mail        83912 Nov 18  2017 /usr/bin/procmail
  2091  160 -rwsr-xr-x   1 root     root       162424 Jan  6  2012 /usr/bin/find
 30731  916 -rwsr-xr-x   1 root     root       937564 Feb 11  2018 /usr/sbin/exim4
  2577   12 -rwsr-xr-x   1 root     root         9660 Jun 20  2017 /usr/lib/pt_chown
144330  244 -rwsr-xr-x   1 root     root       248036 Jan 27  2018 /usr/lib/openssh/ssh-keysign
  7139    8 -rwsr-xr-x   1 root     root         5412 Mar 28  2017 /usr/lib/eject/dmcrypt-get-device
145809  316 -rwsr-xr--   1 root     messagebus   321692 Feb 10  2015 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
 31105   84 -rwsr-xr-x   1 root     root        84532 May 22  2013 /sbin/mount.nfs
```

Figura 42 – Lista dos binários com bit SUID ativo

O binário *find* tem uma vulnerabilidade associada quando este tem o bit SUID ativo, onde permite a execução do mesmo com os privilégios *root*, mas a sessão permanece *root* após o fim da execução do binário. [referência para https://gtfobins.org/gtfobins/find/#shell]
Com este efeito, através da execução controlada do binário *find*, foi possível obter uma shell com privilégios elevados, resultando no acesso ao sistema como utilizador *root*. A Figura 43 demonstra a execução do binário e o acesso com privilégios *root* na máquina.

```
flag4@DC-1:/$ /usr/bin/find . -exec /bin/bash -p \; -quit
bash-4.2# whoami
root
bash-4.2# cd /root
bash-4.2# ls
thefinalflag.txt
bash-4.2# cat thefinalflag.txt
Well done!!!!

Hopefully you've enjoyed this and learned some new skills.

You can let me know what you thought of this little journey
by contacting me via Twitter - @DCAU7
bash-4.2# id
uid=1001(flag4) gid=1001(flag4) euid=0(root) groups=0(root),1001(flag4)
bash-4.2#
```

Figura 43 – Execução do binário *find* e acesso à máquina com privilégios *root*

Este acesso confirmou o comprometimento total do sistema.
Técnicas do MITRE ATT&CK associadas:

- T1068 – Privilege Escalation
- T1548 – Abuse Elevation Control Mechanism

6.5 Análise Global de Risco

A combinação das vulnerabilidades identificadas demonstra uma cadeia de ataque completa, desde o acesso inicial até ao controlo total do sistema:

1. Serviço *web* exposto e desatualizado;
2. Vulnerabilidade crítica com *exploit* público;
3. Execução remota de código;
4. Escalada de privilégios para *root*.

Este cenário evidencia falhas graves ao nível de:

- Gestão de atualizações;
- *Hardening* do sistema;
- Monitorização e deteção de intrusões.

6.6 Proposta de Novo Servidor Seguro

De modo a evitar ter um servidor vulnerável da empresa exposto na Internet, foi escolhido a substituição total do mesmo por um muito mais seguro e com versões mais recentes dos serviços previamente configurados.
Para este efeito, foi escolhido o Sistema Operativo Debian 13.3.0, onde este ainda é suportado de atualizações de segurança e é uma distribuição amplamente utilizada em ambiente empresarial.
Logo de imediato, foi ativado as atualizações de segurança automáticas, assim existe a garantia de que o servidor esteja sempre atualizado à última versão estável suportada.
Juntamente com esta medida, foi seguido o princípio de menor privilégio, onde cada utilizador do sistema apenas tem as permissões necessárias para o que for preciso, e também, o *login* para utilizador *root* foi desabilitado.

6.6.1 Serviços configurados no novo servidor

Foram mantidos os serviços e frameworks anteriormente configurados, mas com versões mais recentes e seguras, nomeadamente:

1. Drupal 11.3.3 com Apache/2.4.66 e PHP 8.4.16 para acesso HTTPs
   Foi forçado a utilização de HTTPs de modo a encriptar todo o tráfego ao website e também foi ativado as atualizações automáticas da aplicação, juntamente com o princípio do menor privilégio aos utilizadores da aplicação
2. OpenSSH 10.0p2
   Foi limitado o acesso a IPs autorizados que pertencem à equipa de Informática da empresa CodeSecure e foi apenas permitido a utilização de algoritmos criptográficos fortes
3. RPCbind
4. MariaDB 11.8.3 para integrar com o Drupal

A Figura 44 apresenta a página principal do servidor HTTPs configurado com Drupal 10

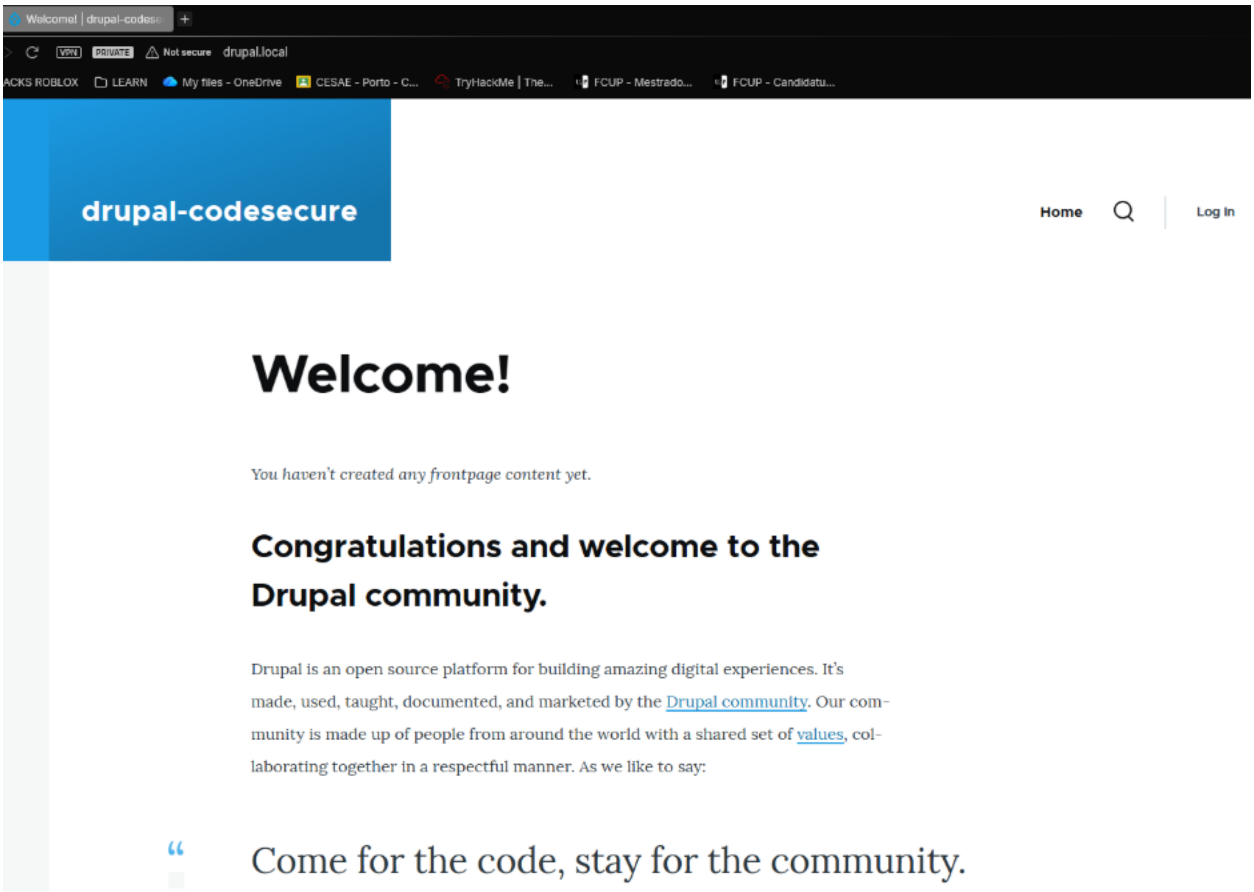


Figura 44 – Página inicial do Drupal 11.3.3

6.6.2 Configurações adicionais

Juntamente com os serviços do ponto 5.6.1, foram adicionadas configurações adicionais para que o sistema esteja totalmente seguro.
Essas configurações incluem:

- Instalação e configuração de uma firewall para permitir o acesso apenas aos serviços configurados e negar tudo o resto. Ferramenta/serviço utilizada: *ufw*
- Instalação e configuração de uma Web Application Firewall (WAF) para detetar ataques web direcionados à aplicação disponível. Ferramenta/serviço utilizada: ModSecurity
- Instalação de um Intrusion Prevention System (IPS) para prevenir ataques de *brute-force* no serviço SSH. Ferramenta utilizada: *fail2ban*
- Aplicado um módulo de segurança Linux que permite definir as permissões que cada programa pode ter, aplicando o princípio de menor privilégio aos mesmos. Ferramenta utilizada: *AppArmor*
- Backups automáticos. Ferramenta utilizada: *rsnapshot*

A Figura 45 mostra o estado das diferentes configurações que foram adicionadas, como a *firewall*, o *fail2ban*, a WAF no servidor HTTPs, as regras da WAF, o *rsnapshot* e o *AppArmor*, respetivamente.

```
root@codesecure:~# ufw status
Status: active

To                         Action      From
--                         ------      ----
22/tcp                     ALLOW       Anywhere
80/tcp                     ALLOW       Anywhere
443/tcp                    ALLOW       Anywhere
111/tcp                    ALLOW       Anywhere
111/udp                    ALLOW       Anywhere
22/tcp (v6)                ALLOW       Anywhere (v6)
80/tcp (v6)                ALLOW       Anywhere (v6)
443/tcp (v6)               ALLOW       Anywhere (v6)
111/tcp (v6)               ALLOW       Anywhere (v6)
111/udp (v6)               ALLOW       Anywhere (v6)

root@codesecure:~# fail2ban-client status
Status
|- Number of jail:      1
`- Jail list:   sshd
root@codesecure:~# apachectl -M | grep security
AH00558: apache2: Could not reliably determine the server's fully qualified domain name, using 127.0.1.1. Set the 'ServerName' directive globally to suppress th
is message
 security2_module (shared)
root@codesecure:~# grep SecRuleEngine /etc/modsecurity/modsecurity.conf
SecRuleEngine On
# when SecRuleEngine is set to DetectionOnly mode in order to minimize
root@codesecure:~# rsnapshot configtest
Syntax OK
root@codesecure:~# systemctl status apparmor.service
● apparmor.service - Load AppArmor profiles
     Loaded: loaded (/usr/lib/systemd/system/apparmor.service; enabled; preset: enabled)
     Active: active (exited) since Wed 2026-02-18 23:08:59 WET; 13min ago
 Invocation: 769d7ad54ad04ab4b3b68060396fd635
       Docs: man:apparmor(7)
             https://gitlab.com/apparmor/apparmor/wikis/home/
   Main PID: 510 (code=exited, status=0/SUCCESS)
   Mem peak: 7M
        CPU: 163ms

Feb 18 23:08:59 codesecure systemd[1]: Starting apparmor.service - Load AppArmor profiles...
Feb 18 23:08:59 codesecure apparmor.systemd[510]: Restarting AppArmor
Feb 18 23:08:59 codesecure apparmor.systemd[510]: Reloading AppArmor profiles
Feb 18 23:08:59 codesecure systemd[1]: Finished apparmor.service - Load AppArmor profiles.
root@codesecure:~#
```

Figura 45 – Estado das diferentes configurações efetuadas no servidor seguro

6.7 Síntese dos Resultados

A análise realizada demonstrou como um servidor desatualizado e mal configurado pode ser comprometido de forma relativamente simples, através de uma cadeia de ataque que incluiu exploração de aplicação web, execução remota de código e escalada de privilégios até root.

O enquadramento das atividades na framework MITRE ATT&CK permitiu contextualizar tecnicamente cada fase do ataque segundo padrões reconhecidos internacionalmente.

Por contraste, a implementação do novo servidor evidenciou que a aplicação de boas práticas — atualizações regulares, princípio do menor privilégio, firewall, WAF, IPS e monitorização — reduz significativamente a superfície de ataque.

Conclui-se que a segurança deve ser contínua e preventiva, sendo a correta configuração e manutenção dos sistemas um fator crítico para proteger a infraestrutura organizacional.

7. Conclusão

O trabalho desenvolvido permitiu conceber e implementar uma infraestrutura de rede empresarial segura e funcional para a CodeSecure, Lda., abrangendo desde o planeamento do endereçamento IP até à configuração de serviços e mecanismos de segurança.
A segmentação por VLANs, aliada às ACLs implementadas no Firewall e nos Core Switches, garante que cada zona da rede tem apenas os acessos estritamente necessários ao seu funcionamento, seguindo o princípio de least privilege. A redundância implementada através do HSRP, do Spanning-Tree e das rotas de backup assegura a continuidade do serviço em caso de falha de equipamentos críticos.
O servidor de partilha de ficheiros baseado em Ubuntu Server com Samba demonstrou ser uma solução eficaz e segura para a partilha departamental de ficheiros, com permissões granulares por grupo e medidas de hardening adequadas ao seu papel na infraestrutura.
As medidas de hardening aplicadas em todos os equipamentos e servidores, incluindo SSH em vez de Telnet, port security, desativação de portas não utilizadas, firewall UFW, Fail2Ban e desativação do SMBv1, demonstram uma abordagem de defesa em profundidade consistente com as melhores práticas da indústria.
Em suma, o projeto permitiu aplicar de forma integrada os conhecimentos adquiridos ao longo do curso nas áreas de redes, administração de sistemas e cibersegurança, resultando numa infraestrutura que, embora simulada, reflete as preocupações e práticas de um ambiente empresarial real.

8. Referências Bibliográficas

https://ubuntu.com/server/docs/
https://www.samba.org/samba/docs/

https://learn.microsoft.com/en-us/windows-server/
https://security-tracker.debian.org/tracker/
https://www.openssh.org/manual.html
https://documentation.wazuh.com/current/index.html
https://yara.readthedocs.io/en/latest/
https://nmap.org/book/man.html
https://docs.tenable.com/nessus/
https://github.com/vanhauser-thc/thc-hydra
https://docs.metasploit.com/
https://attack.mitre.org/
https://www.cve.org/
https://nvd.nist.gov/
https://www.drupal.org/security
https://httpd.apache.org/docs/
https://owasp.org/www-project-top-ten/
https://www.nist.gov/cyberframework
https://github.com/fail2ban/fail2ban
https://modsecurity.org/
https://gtfobins.org/gtfobins/find/